UNIVERSIDAD
NACIONAL DE
INGENIERIA

AREA DE CONOCIMIENTO DE TECNOLOGIA DE LA INFORMACION Y COMUNICACION

"Auditoria de la Red cableada e inalámbrica del Instituto Nicaragüense de Energía (INE) Managua usando norma ISO/IEC 27001:2013"

TRABAJO MONOGRAFICO PARA OPTAR AL TITULO DE INGENIERO EN COMPUTACION

Elaborado por:		Tutor:
Br. Migdalia Junieth Carcache Huerta Carnet: 2010-33210	Br. Carlos Fernando García Alemán Carnet: 2012-44173	MSc. Ing. Marvin David Castañeda

Jueves 10 de Abril de 2025

DEDICATORIA:

Esta dedicatoria va dirigida especialmente a Dios, por permitirme culminar esta etapa de mi vida, por darme sabiduría, fortaleza por hacerme entender y guiarme en el camino que debo seguir.

A mis padres Trinidad García y Esther Alemán quienes centraron sus esfuerzos por hacerme un profesional funcional para la sociedad enseñándome y brindándome muchos ejemplos tales como son la perseverancia, la disciplina y la constancia a mis hermanos Josseling y Gabriel quienes me apoyaron desde el inicio de la carrera a mis familiares, amigos, compañeros, al profesor Msc. Ing. Marvin David Castañeda que con su ayuda profesional y su excelente guía nos ayudó a nuestro desarrollo profesional brindándonos su apoyo y buenos consejos a lo largo del desarrollo de esta tesis monográfica y a las demás personas que a lo largo de este tiempo me apoyaron.

Y finalmente a la prestigiosa Universidad Nacional de Ingeniería que me enseñó a ser una persona integral y de buenos valores.

Carlos Fernando García Alemán

Primeramente, agradecerle a Dios por acompañarme a lo largo de mi carrera y guiarme en mi aprendizaje, ayudarme en momentos de debilidad y darme la inteligencia necesaria para seguir adelante. Le doy gracias a mi papá Luis Ramón Carcache Pastora (Q.E.P.) y mi mamá Bernarda Lourdes Huerta Icabalzeta por estar a mi lado y apoyarme en todo momento, por inculcarme los valores que tengo y por permitirme tener una excelente educación a lo largo de mi vida, y ser siempre el mejor ejemplo a seguir y salir adelante. A mis hermanos Luis Ramón Carcache Huerta, Luis Arístides Carcache Huerta, Herzan Francisco Carcache Huerta por estar siempre a mi lado y brindarme su apoyo siempre que lo he necesitado, y ser una gran parte en mi vida, además de su gran apoyo en mi formación tanto como personal como profesional estando siempre presentes en todo momento y al igual que a nuestro tutor el Ing. MSc. Ing. Marvin David Castañeda el cual siempre nos ayudó y motivo a lo largo de este camino lleno de obstáculos.

Y por supuesto a la empresa Instituto Nicaragüense de Energía (INE), la cual nos permitió realizar esta monografía basándonos en sus instalaciones, los cuales siempre nos brindaron apoyo en momentos de duda y aprendizaje para realizar un buen trabajo monográfico.

Migdalia Junieth Carcache Huerta

AGRADECIMIENTOS:

Queremos expresar nuestro más sincero agradecimiento a todas las personas que han formado parte de este extenso y enriquecedor proceso de investigación y redacción de nuestra monografía. Cada uno de ustedes ha contribuido de manera especial a la realización de este importante proyecto académico.

En primer lugar, nuestra gratitud va dirigida hacia nuestras familias, que han sido nuestro refugio durante este viaje. Ellos nos han enseñado la valiosa lección de nunca dejar de apreciar y disfrutar los pequeños grandes momentos de la vida, incluso en medio del caos y la ocupación que este proyecto nos representó.

Un agradecimiento muy especial al MSC Marvin Castañeda, nuestro tutor incondicional en cada paso de este camino. Su presencia, apoyo y comprensión han sido esenciales para superar cada uno de los desafíos que enfrentamos durante la elaboración de esta monografía.

A nuestros amigos que merecen una mención especial por todas esas noches de diversión que ofrecieron un respiro y me permitieron mantener el equilibrio durante los momentos más intensos de estudio. Gracias por las risas, las celebraciones y por estar siempre ahí para recargar nuestras energía y ánimos.

Debemos destacar y agradecer profundamente a nuestros padres. Su dedicación, paciencia y sabiduría han sido fundamentales en el desarrollo de esta investigación. Gracias a ellos, por invertir tanto tiempo y esfuerzo en nosotros y en el proyecto, por sus valiosos consejos y por mantener la calma en cada etapa de este proceso.

Finalmente, agradecemos a aquellas personas que, a menudo sin saberlo, nos dieron palabras de aliento y motivación. Gracias a todos y cada uno por ser parte de este logro. Este trabajo no solo refleja nuestro esfuerzo, sino también el apoyo y el amor de todos ustedes.

INDICE DE CONTENIDO

1. INTRODUCCIÓN 1
2. ANTECEDENTES 2
3. JUSTIFICACIÓN 3
4. OBJETIVOS: 4
4.1 OBJETIVO GENERAL: 4
4.2 OBJETIVO ESPECÍFICO 4
5. MARCO TEÓRICO 5
5.1 AUDITORIA DE RED: 5
5.2 ¿QUÉ ES ISO/IEC 27001? 5
5.2.1 ¿CÓMO BENEFICIARÁ ISO/IEC 27001 Al INE? 5
5.2.2 PRINCIPIOS DE LA SEGURIDAD DE LA INFORMACIÓN EN ISO/IEC27001 6
5.3 POLÍTICA DE SEGURIDAD 6
5.4 Plan de Gestión de Seguridad de la Información (PGSI): 6
5.5 PRINCIPALES TIPOS DE SEGURIDAD INFORMÁTICA. 6
5.5.1 SEGURIDAD DE HARDWARE: 7
5.5.2 SEGURIDAD DE SOFTWARE: 7
5.5.3 SEGURIDAD DE RED: 7
5.6 Principales leyes y entes reguladores con respecto a la seguridad informática en Nicaragua. 7
5.6.1 La Ley No. 787: 7
5.6.2 El Código Penal y la Ley 787: 7
5.6.3 La Ley No. 200: 7
5.6.3 LEY ESPECIAL DE CIBERDELITOS LEY N°. 1042: 7
5.7 Herramientas de seguridad informática indispensables. 8
5.8 Análisis comparativo de soluciones de seguridad inalámbrica. 9
5.8.1 Plan de Gestión de Seguridad de la Información (PGSI): 9
5.8.2 Sistema para la prevención de intrusos. 9
5.9 Análisis de vulnerabilidades. 9
6. DISEÑO METODOLOGICO 10
7. ESTADO ACTUAL, ANALISIS Y DIAGNOSTICO DE SGSI ISO27001 DEL INSTITUTO NICARAGÜENSE DE ENERGÍA. 12
7.1 Cláusula Contexto. 12
7.2 Cláusula Liderazgo 16
7.3 Cláusula Planificación. 20
7.4 Clausula Soporte. 25

7.5 Cláusula Operaciones. 29
7.6 Cláusula Evaluación del desempeño..... 32
7.7 Clausula Mejora..... 41
7.8 Clausula Seguridad en las Comunicaciones. 49
7.9 Cláusula Adquisición, Desarrollo y Mantenimiento de la red. 53
7.10 Cláusula Relaciones con Proveedores. 57
7.11 Cláusula Gestión de Incidentes de Seguridad de la Información. 60
7.12 spectos de Seguridad de la Información para la Gestión de Continuidad del Negocio 64
7.13 Cláusula Cumplimiento. 66
8. Diagnóstico de la situación actual y análisis del nivel de madurez del SGSI. ... 71
9. Proceso de elaboración del PGSI..... 75
9.1 Análisis Estratégico. 75
9.1.1 Valor generado. 75
9.2 Diseño de Estrategias. 75
9.2.1 Identificación de Estrategias 75
9.2.2 Datos Compuestos en la Identificación de Estrategias 76
9.2.3 Descripción Detallada de las Estrategias..... 77
9.3 Plan de acción. 78
10. Estrategias. 81
11. Resumen Ejecutivo. 82
11.1 Exposición al riesgo de la plataforma 82
12. Detalle Técnico de Vulnerabilidades y Análisis. 83
13. Cronograma de Actividades..... 84
14. Análisis de costo. 87
14.1 Costos de Auditoría Basada en ISO27001. 87
15. CONCLUSIONES. 88
16. RECOMENDACIONES: 89
17. Bibliografía 90
18. Anexos: II
18.1 Diagrama Final de INE II

ÍNDICE DE ILUSTRACIONES

Ilustración 1 del ciclo PHVA shewhart Deming"Autoria propia". 11
Ilustración 2 Contexto "autoría propia" 12
Ilustración 3 Porcentaje de cumplimiento de contexto "autoría propia". 15
Ilustración 4 Liderazgo "autoría propia". 16
Ilustración 5 Porcentaje de cumplimiento liderazgo "autoría propia" 20
Ilustración 6 Planificación "autoría propia" 20
Ilustración 7 Porcentaje de cumplimiento Planificación "autoría propia" 25
Ilustración 8 Soporte. "autoría propia" 26
Ilustración 9 Porcentaje de cumplimiento Soporte "autoría propia" 29
Ilustración 10 Operaciones "autoría propia" 29
Ilustración 11 Porcentaje de cumplimiento de operaciones "autoría propia" .. 32
Ilustración 12 Evaluación del desempeño "autoría propia" 32
Ilustración 13 Porcentaje de cumplimiento Evaluación del desempeño 34
Ilustración 14 Mejora "autoría propia" 41
Ilustración 15 Porcentaje de cumplimiento de la cláusula mejora "autoría propia. 48
Ilustración 16 Seguridad en las Comunicaciones" Autoría propia". 49
Ilustración 17 Porcentaje de cumplimiento de Seguridad en las Comunicaciones "autoría propia" 53
Ilustración 18 Adquisición, Desarrollo y Mantenimiento de la red "autoría propia" 54
Ilustración 19 Porcentaje de cumplimiento de Adquisición, Desarrollo y Mantenimiento de la red "autoría propia" 57
Ilustración 20 Relaciones con Proveedores "autoría propia" 58
Ilustración 21 Porcentaje de cumplimiento de Relaciones con Proveedores "autoría propia" 60
Ilustración 22 Gestión de Incidentes de Seguridad de la Información 60
Ilustración 23 Gestión de Incidentes de Seguridad de la Información 64
Ilustración 24 Aspectos de Seguridad de la Información para la Gestión de Continuidad del Negocio "autoría propia" 64
Ilustración 25 Porcentaje de cumplimiento de Aspectos de Seguridad de la Información para la Gestión de Continuidad del Negocio "autoría propia" 65
Ilustración 26 Cumplimiento "autoría propia" 66
Ilustración 27 Porcentaje de cumplimiento Final "autoría propia" 70
Ilustración 28 Porcentaje de Cumplimiento. "Autoría propia" 74
Ilustración 29 Cantidad de incumplimientos a los controles. "Autoría propia" 74
Ilustración 30 Porcentaje de Riesgos en el Segmento de Red "autoría propia" 82
Ilustración 31 Equipos Afectados por Nivel de Riesgo "autoría propia" 83
Ilustración 32 Diagrama de la red INE "referencia propia" II
Ilustración 33 Estado de Controles -Anexo A III
Ilustración 34 Estado de Implementacion SGSI III

RESUMEN.

El presente trabajo consiste en una auditoría de la red cableada e inalámbrica del Instituto Nicaragüense de Energía (INE) en Managua, enfocándose en el análisis de las vulnerabilidades y problemáticas que afectan a dichas redes conforme a los estándares IEEE 802.11 y los controles de seguridad establecidos por la norma ISO/IEC 27001. Este estudio, programado para realizarse en el primer semestre del 2023, busca ofrecer una descripción detallada del estado actual de las infraestructuras de red del INE, identificando los principales riesgos y proponiendo soluciones para mitigar las dificultades encontradas.

La motivación para esta auditoría surge de la necesidad de abordar los ataques directos que han afectado a equipos como PC, router. y servidores que facilitan servicios de Internet. Estos ataques generalmente se centran en los puertos de comunicaciones y han sido una constante preocupación desde las violaciones significativas ocurridas en redes nicaragüenses en el año 2018. Además, se consideran las amenazas comunes como la proliferación de spam, troyanos, malware y virus informáticos.

La auditoría no solo se centrará en identificar las vulnerabilidades técnicas de la red, sino que también se analizarán los procedimientos y políticas de seguridad implementados por el INE para garantizar la protección de la información confidencial y la integridad de los datos. Se examinará la efectividad de los controles de acceso, la gestión de contraseñas, la política de actualizaciones de software, así como los protocolos de respuesta ante incidentes de seguridad.

Además, se llevará a cabo un análisis exhaustivo de la infraestructura física de la red, incluyendo la ubicación y protección de los puntos de acceso, la segregación de redes, y la redundancia de red para garantizar la disponibilidad y continuidad del servicio en caso de fallos o ataques. Se buscará no solo fortalecer la seguridad de la red en términos tecnológicos, sino también promover en el Instituto Nicaragüense de Energía la importancia de la ciberseguridad y la responsabilidad de cada usuario dentro del Instituto.

El objetivo de esta auditoría es diagnosticar de manera precisa la situación actual de las redes cableadas e inalámbricas del INE para identificar y evaluar los riesgos a los que está expuesto el instituto. A partir de este diagnóstico, se buscará desarrollar estrategias efectivas que contribuyan a la mejora de la seguridad y eficiencia de las redes, asegurando así la integridad, confiabilidad de la información que maneja el Instituto Nicaragüense de Energía.

1. INTRODUCCIÓN

El objeto de estudio de este trabajo en las redes del INSTITUTO NICARAGUENSE DE ENERGIA (INE) en Managua tiene como fin analizar la problemática que ha estado teniendo la RED cableada e inalámbrica en dicha institución con el estándar IEEE 802.11 y los controles de seguridad ISO/IEC 27001, para realizarse en el primer semestre del 2023. Para ello, se realizará una descripción del estado actual de las redes y se identificaran problemáticas existentes para sugerir mejoras a las dificultades identificadas.

Los ataques directos a los equipos computacionales como son pc, Router, server que se encuentran prestando servicios a Internet, en general la experiencia ha enseñado que son atacados por sus diversos puertos de comunicaciones en todo el mundo y desde las violaciones que muchas redes sufrieron en Nicaragua en el año 2018 ha sido una preocupación prioritaria investigar si la Red cableada e Inalámbrica de esta institución (INE), están expuesta a alguna de estas problemáticas, además de las ya normales de proliferación de correos basura (*spam*), troyanos, malware y de virus informáticos que existen en el espectro tecnológico.

Bajo este contexto surge la presente auditoria, la cual se enfoca en el diagnóstico de la situación actual en torno a la Red cableada e inalámbrica, con el objetivo de identificar los riesgos a los que se expone el Instituto Nacional de Energía (INE) y que necesitan ser mejorados.

En este contexto, es esencial comprender que la seguridad de la red no solo implica la protección de los datos y los sistemas informáticos, sino también la preservación de la integridad y disponibilidad de los servicios críticos que ofrece el INE a través de su infraestructura de red. Por lo tanto, además de evaluar las vulnerabilidades técnicas, es crucial analizar la capacidad de la red para resistir posibles interrupciones en el servicio debido a ataques cibernéticos, fallos de hardware o desastres naturales.

Además, dado el entorno cambiante de las amenazas cibernéticas, es fundamental que el INE adopte un enfoque proactivo hacia la seguridad de la red, implementando medidas de monitoreo continuo y actualizaciones regulares de sus sistemas y políticas de seguridad. Esto garantizará que la institución esté preparada para enfrentar nuevas amenazas y responder de manera efectiva ante incidentes de seguridad, minimizando así el impacto en sus operaciones y reputación.

En última instancia, esta auditoría no solo proporcionará recomendaciones específicas para mejorar la seguridad de la red del INE, sino que también servirá como una herramienta para fomentar una mayor colaboración y coordinación entre los diferentes departamentos y áreas de la institución en materia de ciberseguridad. La protección de la red es una responsabilidad compartida que requiere el compromiso y la participación activa de todos los miembros de la organización

2. ANTECEDENTES

Para el desarrollo de esta tesis se ha consultado en varios proyectos de investigación enfocados a la implementación de un plan de gestión de seguridad informática basándose en la ISO Estándar 27001. La investigación se enfocará en identificar las vulnerabilidades comunes en la seguridad informática y en desarrollar estrategias efectivas para prevenir y mitigar las amenazas cibernéticas, siguiendo una metodología de Seguridad basado en la norma ISO/IEC 27001. Además, se investigará la importancia de la capacitación y concientización del personal en la seguridad informática como una medida preventiva clave para culminar con éxito el proyecto. (Maizal, 2005)

En la Universidad Central del Ecuador, Diego Alejandro Romero Quevedo ha desarrollado un proyecto de investigación titulado "Implementación de un esquema de seguridad para la red de la Unidad Educativa Particular Cardenal Spellman Femenino", en la que realiza un diagnóstico para la implementación de un esquema de seguridad en la red mediante búsqueda de fallos, técnicas de Hacking Ético y configuraciones de dispositivos de la infraestructura informática basándose en el Esquema Gubernamental de Seguridad Informática (EGSI) y estableciendo Políticas de Seguridad con Normativas Estándar. (ISO STANDAR, 2005)

En Colombia, Benjamín José Ramírez Montealegre de la Universidad Nacional de Colombia ha desarrollado un proyecto de investigación titulado "Medición de madurez de Ciberseguridad en MiPymes colombianas" en la cual explica la influencia que tiene al no invertir en seguridad de datos hace que una empresa sea vulnerable a cualquier ataque de personas propias o ajenas a la empresa.

En Nicaragua Díaz Otero Marcel Enrique de la Universidad Nacional de Ingeniería desarrollo un proyecto de investigación "Auditoría de seguridad basado en el Standard ISO 27001.2013 SGSI (Sistema de Gestión de Seguridad de la Información)" en la que realiza un diagnóstico para la implementación de un esquema de seguridad en red mediante la búsqueda de fallos basándose en el uso de la norma ISO 27001.

El análisis exhaustivo de estos proyectos de investigación proporcionará un marco de referencia sólido para la realización de esta auditoría de seguridad en las redes del Instituto Nicaragüense de Energía (INE). Al aprovechar las lecciones aprendidas y las mejores prácticas identificadas en proyectos similares, se podrá desarrollar un enfoque integral y eficaz para abordar las vulnerabilidades y desafíos específicos que enfrenta el INE en materia de seguridad informática. La implementación de un plan de gestión de seguridad informática basado en estándares reconocidos internacionalmente, como la norma ISO/IEC 27001, servirá como una guía fundamental para fortalecer la postura de seguridad del INE y proteger sus activos críticos de información contra posibles amenazas cibernética.

3. JUSTIFICACIÓN

El INSTITUTO NICARAGUENSE DE ENERGIA (INE) ha constado con un sistema de gestión unificada de amenazas de Red de Datos (UTM), resguardando la seguridad de esta red de la mejor manera sin haber algún incidente informático de peligro hasta el momento, pero cabe destacar que se tiene ya algunos años de funcionamiento sin que exista un estudio de las vulnerabilidades de la red informática que este bajo algún estándar de Calidad hasta hoy.

Actualmente el INSTITUTO NICARAGUENSE DE ENERGIA (INE), cuenta con una red informática que le garantiza la conectividad en todas sus oficinas y la comunicación con las filiales en los departamentos.

Ha sido una prioridad para el INSTITUTO NICARAGUENSE DE ENERGIA (INE) mejorar la infraestructura de esta red informática(interna) para la calidad de sus servicios. El INE, ve necesario organizar y establecer nuevas soluciones de seguridad debido al tiempo que tienen sus equipos activos de Red y sus equipos que resguardan el perímetro de seguridad de la misma. Para esto es necesario hacer una auditoria de Red informática que permita analizar si existen vulnerabilidades que estén poniendo en riesgo la información de la Institución esto se hará siguiendo una metodología ISO/IEC 27001 y de esta forma garantizar la calidad de los servicios y los datos que se mueven en la red de la institución.

El uso de un sistema de gestión unificada de amenazas de red de datos (UTM) ha sido una medida acertada por parte del INE para salvaguardar la integridad y confidencialidad de su red informática. Sin embargo, la falta de un estudio exhaustivo de las vulnerabilidades bajo estándares de calidad representa una brecha en la estrategia de seguridad de la institución. Es crucial reconocer que la ausencia de incidentes informáticos hasta la fecha no garantiza la inmunidad frente a futuros ataques, especialmente en un entorno tecnológico en constante evolución y donde las amenazas cibernéticas son cada vez más sofisticadas.

La conectividad proporcionada por la red informática del INE es fundamental para la eficiencia operativa y la comunicación fluida entre sus distintas sedes y filiales. Sin embargo, esta interconexión también aumenta la superficie de ataque y la exposición a posibles amenazas externas e internas.

El objetivo principal de esta auditoría es garantizar la calidad de los servicios y la protección de los datos que circulan a través de la red del INE. Al seguir una metodología rigurosa y estandarizada, la institución podrá obtener una evaluación objetiva de su postura de seguridad y desarrollar estrategias efectivas para fortalecer sus defensas cibernéticas. Además, la auditoría servirá como un punto de partida para la implementación de medidas preventivas y correctivas que aseguren la integridad y confiabilidad de la red del INE a largo plazo.

4. OBJETIVOS:

4.1 OBJETIVO GENERAL:

- ✓ Realizar una auditoría de red informática al INSTITUTO NICARAGUENSE DE ENERGIA INE bajo la norma ISO/IEC 27001:2013 con el propósito de identificar posibles riesgos y vulnerabilidades.

4.2 OBJETIVO ESPECÍFICO

- ✓ Analizar la infraestructura de la red del Instituto Nicaragüense de Energía para identificar los posibles riesgos y vulnerabilidades presentes en la misma.
- ✓ Elaborar un PGSI (Plan de Gestión de Seguridad de la Información) en función de cerrar las brechas encontradas en la red informática del Instituto Nicaragüense de Energía (INE) según el estándar internacional ISO-IEC 27001.
- ✓ Evaluar mediante pruebas de penetración, el impacto que pueda tener un ataque de seguridad a la red Informática del Instituto Nicaragüense de Energía (INE).
- ✓ Elaborar un informe de los resultados obtenidos en la auditoria, que contenga los hallazgos y recomendaciones pertinentes que le permita a INE mejorar la infraestructura física y lógica de la red.

5. MARCO TEÓRICO

En este proyecto, se aborda el tema de Auditoria de la Red informática del Instituto Nicaragüense de Energía, con el objetivo de realizar un estudio de las vulnerabilidades de la red y mejorar su funcionamiento. Para ello, se hace uso de un marco teórico sólido que contempla diferentes enfoques y perspectivas que permiten una comprensión profunda y completa del tema en cuestión, dentro de esta sección se hará un análisis teórico sobre auditoría, su definición, sus objetivos, importancia, metodología, entre otros elementos necesarios para la comprensión de lo que se abordará durante el proceso de realización de la monografía. (Huerta, A. V. (Julio, 2002).)

5.1 AUDITORIA DE RED:

Una auditoría de redes es un estudio llevado a cabo en la empresa para analizar y recopilar todos los datos posibles sobre la red con el objetivo de identificar posibles fallos para mejorarlos. (Andina, F. (2014).)

5.2 ¿QUÉ ES ISO/IEC 27001?

ISO/IEC 27001 es el estándar más conocido del mundo para sistemas de gestión de seguridad de la información (SGSI). Define los requisitos que debe cumplir un SGSI.

La norma ISO/IEC 27001 proporciona a las empresas de cualquier tamaño y de todos los sectores de actividad orientación para establecer, implementar, mantener y mejorar continuamente un sistema de gestión de seguridad de la información.

La conformidad con ISO/IEC 27001 significa que una organización o empresa ha puesto en marcha un sistema para gestionar los riesgos relacionados con la seguridad de los datos propiedad o manejados por la empresa, y que este sistema respeta todas las mejores prácticas y principios consagrados en esta Norma Internacional.

5.2.1 ¿CÓMO BENEFICIARÁ ISO/IEC 27001 Al INE?

La implementación del marco de seguridad de la información especificado en la norma ISO/IEC 27001 le ayuda a:

- ✓ Reducir su vulnerabilidad a la creciente amenaza de los ciberataques
- ✓ Responder a los riesgos de seguridad en evolución
- ✓ Asegúrese de que los activos como los estados financieros, la propiedad intelectual, los datos de los empleados y la información confiada por terceros permanezcan intactos, confidenciales y disponibles según sea necesario
- ✓ Proporcionar un marco administrado centralmente que protege toda la información en un solo lugar.

- ✓ Prepare a las personas, los procesos y la tecnología en toda su organización para enfrentar los riesgos basados en la tecnología y otras amenazas.
- ✓ Proteja la información en todas sus formas, incluidos los datos en papel, en la nube y digitales.
- ✓ Ahorre dinero aumentando la eficiencia y reduciendo los gastos de tecnología de defensa ineficaz.

5.2.2 PRINCIPIOS DE LA SEGURIDAD DE LA INFORMACIÓN EN ISO/IEC27001

- ✓ **Confidencialidad**: solo las personas adecuadas pueden acceder a la información
- ✓ **Integridad de la información**: los datos que la organización utiliza para llevar a cabo su funcionamiento
- ✓ **Disponibilidad de datos**: El instituto INE y sus clientes pueden acceder a la información siempre que sea necesario.

5.3 POLÍTICA DE SEGURIDAD

Se define una Política General de Seguridad de la Información (PGSI), que garantiza que exista una declaración institucional enfatizando el compromiso de la dirección con los objetivos de Gestión de Seguridad de la Información ISO27001.

La política tiene que contener:

- ✓ Definición de seguridad
- ✓ Medios de difusión de sus contenidos
- ✓ Cada cuanto tiempo se realiza una revisión
- ✓ Periodicidad con la que se evalúa el cumplimiento
- ✓ La aprobación por parte del jefe del Servicio

Los expertos establecen que la política se puede realizar mediante un acuerdo en los formatos que la empresa crea oportunos, pero se tiene que considerar que debe contar con unos contenidos mínimos.

5.4 Plan de Gestión de Seguridad de la Información (PGSI):

Este plan se basa en la norma ISO/IEC 27001 y es una herramienta para establecer, implementar, mantener y mejorar continuamente la gestión de la seguridad de la información en una organización. El PGSI incluye la identificación de los activos de información, la evaluación de riesgos, la definición de controles de seguridad y la implementación de un sistema de gestión de seguridad de la información.

5.5 PRINCIPALES TIPOS DE SEGURIDAD INFORMÁTICA.

Al hablar de seguridad informática es fundamental distinguir algunas de las tipologías que existen, siendo los principales elementos a dar protección el software, la red y el hardware. (TANENBAUM, A. S. (2012)

5.5.1 SEGURIDAD DE HARDWARE:

Este tipo de seguridad se relaciona con la protección de dispositivos que se usan para proteger sistemas y redes —apps y programas de amenazas exteriores—, frente a diversos riesgos. El método más usado es el manejo de sistemas de alimentación ininterrumpida (SAI), servidores proxy, firewall, módulos de seguridad de hardware (HSM) y los data lost prevention (DLP). Esta seguridad también se refiere a la protección de equipos físicos frente a cualquier amenaza.

5.5.2 SEGURIDAD DE SOFTWARE:

Usado para salvaguardar los sistemas frente ataques malintencionados de hackers y otros riesgos relacionados con las vulnerabilidades que pueden presentar el software. A través de estos “defectos” los intrusos pueden entrar en los sistemas, por lo que se requiere de soluciones que aporten, entre otros, modelos de autenticación.

5.5.3 SEGURIDAD DE RED:

Principalmente relacionada con el diseño de actividades para proteger los datos que sean accesibles por medio de la red y que existe la posibilidad de que sean modificados, robados o mal usados. Las principales amenazas en esta área son: virus, troyanos, phishing, programas espía, robo de datos y suplantación de identidad. (Huerta, A. V. (Julio, 2002).)

5.6 Principales leyes y entes reguladores con respecto a la seguridad informática en Nicaragua.

5.6.1 La Ley No. 787:

sobre Derechos de Autor y Derechos Conexos, publicada en el Diario Oficial La Gaceta No 60 del 24 de marzo del 2006, donde se tutela la protección de los derechos de autor en cualquier medio de expresión.

5.6.2 El Código Penal y la Ley 787:

son los instrumentos jurídicos que protegen a los nicaragüenses contra los delitos cibernéticos.

5.6.3 La Ley No. 200:

Ley General de Telecomunicaciones y servicios postales, aprobada por la Asamblea Nacional el 07 de diciembre 2009, es la regulación de los servicios de telecomunicaciones y servicios postales, así como de establecer los derechos y deberes de los usuarios y de las operadoras, en condiciones de calidad, equidad, seguridad en Telecomunicaciones.

5.6.3 LEY ESPECIAL DE CIBERDELITOS LEY N°. 1042:

La presente Ley tiene por objeto la prevención, investigación, persecución y sanción de los delitos cometidos por medio de las Tecnologías de la Información y la Comunicación, en perjuicio de personas naturales o jurídicas, así como la protección integral de los sistemas que utilicen dichas tecnologías, su contenido y cualquiera de sus componentes, en los términos previstos en esta Ley.

La cámara nicaragüense de Internet y Telecomunicaciones (CANITEL), organizó el conversatorio sobre los desafíos Tecnológicos de Nicaragua", es de relevancia destacar que se contó con la participación de funcionarios de Google, Airbnb, Uber y del sector privado y público del país.

El 17 de febrero se realizó en Managua el TIC Forum 2017, organizado por Telefónica Business Solutions, en donde se abordó como tema "Ciberseguridad: Protegiendo sus activos digitales".

El Consejo nicaragüense de Ciencia y Tecnología (Conicyt) y Comisión de Gobierno Electrónico de Nicaragua (GobNic) son las principales instituciones del Estados que impulsan la seguridad digital y prevención para ciberdelitos.

5.7 Herramientas de seguridad informática indispensables.

- ✓ Software antivirus. Los antivirus son un básico.
- ✓ Firewall.
- ✓ Servidor proxy.
- ✓ Cifrado de punto final o end point disk encryption.
- ✓ Escáner de vulnerabilidades.
- ✓ Control de acceso a la red (NAC).
- ✓ Sistema de prevención de intrusos (IPS).
- ✓ Contraseñas fuertes.

Mejores herramientas de Windows para monitorear redes inalámbricas.

- ✓ Monitorear de Redes Inalámbricas con OpManager.
- ✓ Site24x7.
- ✓ SolarWinds WiFi monitor.
- ✓ NetSpot.Acrylic Wifi.
- ✓ InSSIDer.

Podemos clasificar las herramientas de Auditoría de red en función de lo que queremos lograr:

- ✓ Inventario de red, diagrama de red, análisis: Solarwinds, Open-Audit, NetformX son ejemplos en esta categoría. Estas herramientas realizarán un inventario, proporcionarán diagramas de red e incluso generarán informes.
- ✓ Evaluación de seguridad: Nessus y Nipper son herramientas de esta categoría que evaluarán la configuración en tus dispositivos y te darán un informe no solo de los problemas, sino que también mostrarán cómo resolverlos.
- ✓ Evaluación de rendimiento: Wireshark es probablemente el rey en este dominio, aunque existen otras herramientas como los analizadores iperf, ntop y NetFlow.

5.8 Análisis comparativo de soluciones de seguridad inalámbrica.

Hoy en día, la implementación de las Tecnologías de la Información y Comunicaciones (TIC) en distintas áreas de la vida cotidiana las ha convertido en una gran herramienta para el desarrollo de los países. Las condiciones de salud y la calidad de vida de las personas son aspectos que se han podido mejorar gracias a la tecnología, así como el intercambio de información entre profesionales y la capacitación de personal, que para todos estos casos evitan grandes desplazamientos a quienes residen en zonas apartadas donde no se presentan algunos tipos de servicios (García Rambla, J. L. (2017))

5.8.1 Plan de Gestión de Seguridad de la Información (PGSI):

Este plan se basa en la norma ISO/IEC 27001 y es una herramienta para establecer, implementar, mantener y mejorar continuamente la gestión de la seguridad de la información en una organización. El PGSI incluye la identificación de los activos de información, la evaluación de riesgos, la definición de controles de seguridad y la implementación de un sistema de gestión de seguridad de la información.

5.8.2 Sistema para la prevención de intrusos.

Intrusion Prevention System (IPS), también conocido como sistema de prevención de detección de intrusiones, es una tecnología que vigila una red para detectar cualquier actividad maliciosa que intente aprovechar la vulnerabilidad conocida. (Huerta, 2020)

5.9 Análisis de vulnerabilidades.

El análisis de vulnerabilidades es un proceso para identificar debilidades en los sistemas y aplicaciones informáticas que podrían ser explotadas por atacantes para acceder o dañar información crítica. Este proceso incluye la identificación de vulnerabilidades conocidas, la evaluación de la criticidad de cada una y la recomendación de medidas para su mitigación. También se incluye una **revisión periódica de cualquier amenaza, riesgo y vulnerabilidades** a las que se enfrenta el sistema de información de una empresa, ante la entrada de terceros no autorizados en él.

6. DISEÑO METODOLOGICO

El método adoptado es de tipo cualitativo se basa en una estrategia de investigación flexible e interactiva. Es un método de investigación más descriptivo que se centra en las interpretaciones, las experiencias y su significado y con la ayuda del ciclo PHVA (Planificar-Hacer-Verificar-Actuar) es una estrategia interactiva de resolución de problemas para mejorar procesos e implementar cambios. El ciclo PHVA es un método de mejoras continuas. No es un proceso que se ejecuta una sola vez, sino un espiral continuo que busca mejorar los procesos e iteraciones. Al seguir el ciclo PHVA, los equipos desarrollan hipótesis, ponen a prueba las ideas y las mejoran.

El ciclo PHVA es una técnica muy útil para abordar, analizar y resolver problemas en empresas. Dado que el ciclo PHVA se basa en el proceso de mejora continua, ofrece un alto nivel de flexibilidad y mejora iterativa.

Cuando usar el ciclo PHVA

El ciclo PHVA es un marco que sirve para abordar y resolver problemas en la gestión de proyectos y procesos. Dada esta naturaleza, se puede implementar en una gran variedad de proyectos. Los equipos que utilizan el ciclo PHVA adoptan eficazmente la mejora continua, ya que les permite garantizar no solo este tipo de mejora, sino también implementar el proceso iterativo.

El ciclo PHVA es útil especialmente cuando se quiere:

- ✓ Simplificar y mejorar un proceso de trabajo repetitivo
- ✓ Desarrollar un proceso de negocios nuevo
- ✓ Comenzar a implementar mejoras continuas
- ✓ Iterar cambios rápidamente y ver resultados inmediatos
- ✓ Minimizar errores y maximizar resultados
- ✓ Probar soluciones múltiples rápidamente

Ilustración 1 del ciclo PHVA shewhart Deming"Autoria propia".

El primer paso será el diseño de las plantillas a utilizar para la recolección y análisis de la información. Para esto se definieron dos plantillas que abarcaron los requerimientos y objetivos de control establecidos en la norma ISO/IEC 27001:2013. Las plantillas desarrolladas están basadas en preguntas abiertas que están alineadas a los requerimientos del ISO/IEC 27001:2013 y a identificar los niveles de madurez de los requerimientos y controles del ISO 27001 e ISO 27002 respectivamente. (CISCO, 2018).

Una vez diseñadas las plantillas, se procederá a la recolección de datos mediante entrevistas con personal clave del INE, incluyendo a responsables de la seguridad de la información, administradores de sistemas y otros stakeholders relevantes.

Posteriormente, se llevará a cabo un análisis exhaustivo de los datos recopilados para identificar patrones, tendencias y áreas de mejora en la seguridad de la red del INE.

Finalmente, se presentará un informe completo que incluirá los hallazgos del análisis de vulnerabilidades, las recomendaciones para mejorar la seguridad de la red y el plan de acción propuesto. Este informe se compartirá con la dirección del INE y otros interesados relevantes para su revisión y aprobación. Además, se proporcionarán capacitaciones y sesiones informativas para el personal del INE con el fin de concienciar sobre las prácticas de seguridad.

El primer paso del análisis de la situación actual es el diseñar las plantillas a utilizar para la recolección y análisis de la información. Para esto se definieron dos plantillas que abarcaron los requerimientos y objetivos de control establecidos en la norma ISO/IEC 27001:2013.

Las plantillas desarrolladas están basadas en preguntas abiertas que están alineadas a los requerimientos del ISO/IEC 27001:2013 y a identificar los niveles de madurez de los requerimientos y controles del ISO 27001 e ISO 27002 respectivamente.

7. ESTADO ACTUAL, ANALISIS Y DIAGNOSTICO DE SGSI ISO27001 DEL INSTITUTO NICARAGÜENSE DE ENERGÍA.

7.1 Cláusula Contexto.

Definición según la cláusula de la norma – Contexto del Instituto Nicaragüense de Energía INE.
Determinar los problemas externos e internos de la red informática de INSTITUTO NICARAGUENSE DE ENERGIA (INE), así como requisitos claros para considerar las partes interesadas. El contexto determina la política de SI, los objetivos y la forma en que el INE tendrá en cuenta el riesgo y el efecto del riesgo en su negocio y los requisitos de las partes interesadas pueden incluir los requisitos legales, reglamentarios y las obligaciones contractuales.
Nivel de Madurez Administrado.
Nivel de madurez general.
Ilustración 2 Contexto "autoría propia"
Situación evidenciada.
Hallazgos satisfactorios.

7.1.1 Clausula Comprender del Instituto Nicaragüense de Energía INE y su contexto.	
7.1.2 Determinar los problemas internos y externos relevantes para el SGSI.	**Hallazgo identificado.**
	Actualmente INE ha documentado el alcance del sistema del SGSI a un nivel intermedio. Este documento debe ser desarrollado para lograr el cumplimiento total. En su desarrollo se puede utilizar la información contenida en el informe de diagnóstico.
	Conclusión y recomendación.
	Se debe definir un documento formal sobre la organización de la Seguridad que defina y establezca el alcance del SGSI del Instituto Nicaragüense de Energía y que determine las partes o procesos de la organización que van a ser incluidos, así como los procesos críticos que quieren protección y el punto de partida, además de la definición de las actividades.
7.1.3 Comprender las necesidades y expectativas de las partes interesadas.	
7.1.4 Se determinan las partes interesadas.	**Hallazgo identificado.**
	Este documento debe ser desarrollado para lograr el cumplimiento del apartado. En su desarrollo se puede utilizar la información contenida en el informe de diagnóstico del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se requiere contar con un documento formal apegado a la Norma Internacional que defina el alcance del SGSI y que determine las partes o procesos del Instituto Nicaragüense de Energía.
7.1.5 Se tienen claros los requerimientos de las partes interesadas.	**Hallazgo identificado.**
	Este documento debe ser desarrollado para lograr el cumplimiento del apartado. En su desarrollo se puede utilizar la información contenida en el informe de diagnóstico del Instituto Nicaragüense de Energía.

	Conclusión y recomendación.
	Para ello se requiere la creación de un documento formal que defina el alcance del SGSI y que defina las partes o procesos del Instituto Nicaragüense de Energía que van a ser incluidos, así como los procesos críticos que se quieren proteger y por donde se va a iniciar, además de la definición de las actividades.
7.1.6 Determinar el alcance del SGSI.	
7.1.7 Se determina la aplicabilidad y limitaciones del SGSI.	**Hallazgo Identificado.**
	Este documento debe ser desarrollado para lograr el cumplimiento del apartado. En su desarrollo se puede utilizar la información contenida en el informe de diagnóstico del Instituto Nicaragüense de Energía.
	Conclusión y recomendación.
	Se debe definir las partes o procesos del Instituto Nicaragüense de Energía que van a ser incluidos, así como los procesos críticos que se requieren proteger y por donde se va a iniciar, además de la definición de las actividades, las ubicaciones físicas que van a verse involucradas, la tecnología y las áreas que quedarán excluidas en la implantación del SGSI, si es procedente.
7.1.8 El alcance se encuentra formalmente documentado.	**Hallazgos identificados.**
	Actualmente se ha documentado el alcance del sistema. Para el cumplimiento se utilizará la información contenida en el informe de diagnóstico del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Hay que documentar el alcance del SGSI del Instituto Nicaragüense de Energía que van a ser incluidos, así como los procesos críticos que se quieren proteger, además de las ubicaciones físicas que van a verse involucradas, la tecnología y las áreas que quedarán excluidas en la implantación del SGSI.
7.1.9 SGSI.	
	Hallazgos identificados.

7.1.10 Se ha establecido, implementado, se da mantenimiento y se mejora continuamente el SGSI.	Está documentado un SGSI básico por parte del Instituto Nicaragüense de Energía. Sin embargo, hay que desarrollar un documento que cumpla con la Norma.
	Conclusiones y recomendaciones.
	Se recomienda definir un proceso formal que establezca los procedimientos para la definición, implantación, mantenimiento y mejora continua del SGSI del Instituto Nicaragüense de Energía.
7.1.11 Nivel de riesgo expuesto – Contexto del INE.	
Bajo	Este tipo de riesgos deben ser minimizados, aunque esto suponga una inversión económica, de tiempo, recursos institucionales, entre otros, siempre y cuando los recursos asignados afecten la operativa o causen nuevos riesgos de otra índole del Instituto Nicaragüense de Energía.

Porcentaje de cumplimiento

Ilustración 3 Porcentaje de cumplimiento de contexto "autoría propia".

Requisitos ISO 27001:2013 – Cláusula Liderazgo.
Definición según la cláusula de la norma – Liderazgo.
Resume los requisitos específicos para el papel de la dirección del Instituto Nicaragüense de Energía INE en el SGSI y delinea formas específicas para demostrar la gestión y su compromiso con el sistema.
Madurez Administrado.
Nivel de madurez general

7.2 Cláusula Liderazgo

Ilustración 4 Liderazgo "autoría propia".

Situación evidenciada.	
Hallazgos No satisfactorios.	
7.2.1 Liderazgo y Recursos.	
7.2.2 Existen recursos suficientes para la implementación y operación del SGSI.	**Hallazgos identificados.**
	En la entrevista con la Dirección de Informática del Instituto Nicaragüense de Energía se informó que existen los recursos para desarrollar el SGSI. Lo que posee actualmente es la discusión del monto presupuestario a solicitar vía Plan Operacional Anual, que deberá quedar establecido después de la Auditoria.
	Conclusiones y recomendaciones.
	De acuerdo a lo anterior se requiere un compromiso de la Institución para presupuestar un monto anual para el mantenimiento del plan de operación del SGSI.
7.2.3 Se comunica la importancia	**Hallazgos identificados.**
	Actualmente existe campaña de comunicación sobre el SGSI aunque hay concientización sobre seguridad de la información y de las redes del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.

un SGSI efectivo y de su cumplimiento	Es indispensable realizar campañas que nos permitan conocer las vulnerabilidades de las redes y los peligros que conllevan el utilizar equipos que no manejan seguridad.

7.2.4 Se garantiza que el SGSI alcance sus objetivos	**Hallazgos identificados.**
	Hay desarrollado un SGSI que permite evaluar para este cumplimiento del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	De acuerdo a los recursos que posee el área de Informática han podido establecer una estrategia en el SGSI del Instituto Nicaragüense de Energía.
7.2.5 Se provee la dirección y el soporte necesario al personal para contribuir con el SGSI.	**Hallazgos identificados.**
	se identifica la existencia del soporte por medio de la publicación de disposiciones Internas, asignación de presupuesto para evaluar lo siguiente: la seguridad, implementación de mecanismos de contingencia seguros, que demuestran el apoyo y soporte del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	A pesar del Instituto Nicaragüense de Energía utiliza un mecanismo válido para dar apoyo y soporte al SGSI, el mismo debe definirse y aplicarse de manera formal mediante el diseño de un proceso formal que incluya un plan de sensibilización y que establezca entre algunos de sus apartados los canales de comunicación y/o soporte, la frecuencia determinada, los responsables de la ejecución.
7.2.6 Se promueve la mejora continua	**Hallazgos identificados.**
	la seguridad de la información se ha convertido en una actividad de relevancia y por ello se planifica la implementación del SGSI del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.

	De acuerdo con lo anterior se recomienda fomentar y establecer un plan de mejora continua formalmente documentado para el SGSI del Instituto Nicaragüense de Energía.
7.2.7 Política.	
	Hallazgos identificados.

7.2.8 La política se encuentra de acuerdo al propósito de la organización.	Existe una política general de seguridad de la información del Instituto Nicaragüense de Energía que tiene la visión general de la institución acorde a normas gubernamentales.
	Conclusiones y recomendaciones.
	De acuerdo a lo anterior, se recomienda incluir en la política general de seguridad de la información de manera clara la visión institucional, para acorde a esto establecer los lineamientos que se ajusten dentro de la seguridad para alcanzar las metas del Instituto Nicaragüense de Energía.
7.2.9 La política incluye los objetivos de seguridad o provee marco para definir los objetivos de seguridad.	**Hallazgos identificados.**
	Existe una política general de seguridad de la información que incluye la misión y la visión general de la institución. del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	De acuerdo a lo anterior se recomienda establecer lineamientos que se ajusten a la seguridad para alcanzar la visión y misión del Instituto Nicaragüense de Energía.
7.2.10 La política incluye un compromiso para acatar los requerimientos aplicables a la seguridad de la información.	**Hallazgos identificados.**
	se establecen los compromisos, sólo las responsabilidades del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se recomienda incluir en las políticas del Instituto Nicaragüense de Energía de manera amplia los compromisos que se deben cumplir en los que respecta a la seguridad de la información.
7.2.11 La	**Hallazgos identificados**

política incluye un compromiso para la mejora continua del SGSI.	Se incluye el compromiso de mejora continua.
	Conclusiones y recomendaciones
	En la política de seguridad de la información del Instituto Nicaragüense de Energía el diseño del control carece de la definición de frecuencia para revisar la política y establecer así un período continuo de mejora a la misma. Es indispensable que al menos dentro del contenido de la política se incluya la frecuencia de revisión que podría ser como mínimo anual.
7.2.12 La política se encuentra formalmente documentada.	**Hallazgos identificados.**
	La política se encuentra documentada, pero ha sido difundida a todos los actores del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	La política del Instituto Nicaragüense de Energía debe cumplir al menos con los siguientes requisitos: ✓ Debe ser aprobada por la dirección y publicada por la misma. ✓ Debe ser de dominio público dentro de la organización. Algunas dependencias y/o funcionarios saben cómo acceder a la política. ✓ Debe indicar que es lo que se protege en la organización (personal, información, imagen, continuidad, reputación). ✓ Debe señalar las reglas y normas que va adoptar la organización y las medidas de seguridad que serán necesarias. ✓ Debe definir lo que es seguridad de la información.
7.2.13 La política es comunicada dentro de la organización.	**Hallazgos identificados.**
	La política, ha sido publicada dentro del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se recomienda incluir dentro del desarrollo del plan de sensibilización una estrategia de comunicación constante de la política de seguridad informática del Instituto Nicaragüense de Energía.

Nivel de riesgo expuesto – Contexto del Instituto Nicaragüense de Energía	
Alto	Este tipo de riesgos deben ser minimizados, aunque esto suponga una inversión económica, de tiempo, recursos del Instituto Nicaragüense de Energía, entre otros, siempre y cuando los recursos asignados afecten la operativa o causen nuevos riesgos de otra índole.

Ilustración 5 Porcentaje de cumplimiento liderazgo "autoría propia"

7.3 Cláusula Planificación.

Definición según la cláusula de la norma – Planeación
Establecimiento de objetivos y principios rectores para el SGSI y planificar el SGSI con base en el contexto del Instituto Nicaragüense de Energía debe ser tenido en cuenta a través de la consideración de los riesgos y oportunidades, los objetivos del Instituto Nicaragüense de Energía deben estar claramente definidos junto con los planes para alcanzarlos.

Ilustración 6 Planificación "autoría propia"

Madurez Repetible	
Nivel de madurez general	
Situación evidenciada.	
Hallazgos satisfactorios.	
7.3.1 Instituto Nicaragüense de Energía considera su contexto y las	**Hallazgos identificados.**
	La evaluación de riesgos se enfoca a las situaciones que puedan afectar la operación del SGSI del Instituto Nicaragüense de Energía.

necesidades y expectativas de las partes interesadas.	**Conclusiones y recomendaciones.**
	Determinar los riesgos y oportunidades que deben tratarse para asegurar que el sistema de gestión de seguridad de la información puede lograr los resultados previstos del Instituto Nicaragüense de Energía.
7.3.2 Determinar los riesgos y oportunidades s que se deben atender para que el SGSI alcance sus objetivos, para prevenir o reducir efectos no deseados.	**Hallazgos identificados.**
	La evaluación de riesgos se enfoca a las situaciones que puedan afectar la operación del SGSI del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se recomienda definir un proceso formal para la gestión de riesgos de seguridad de la información del Instituto Nicaragüense de Energía que evalué e identifique los riesgos y determine las oportunidades o medidas correctivas. Se puede tomar como referencia el marco COBIT 5, para el diseño del proceso de gestión de riesgos.
7.3.3 El proceso de evaluación de riesgos de seguridad de la información asegura que las evaluaciones resultados consistentes, válidos y comparables.	**Hallazgos identificados.**
	se ha logrado convertir en un proceso recurrente. Si bien define los valores a aplicar en la evaluación, carece de documentación de marco normativo que estipule la forma de aplicación de la evaluación de riesgos del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se puede tomar como referencia el marco COBIT 5 para el diseño del proceso de gestión de riesgos del Instituto Nicaragüense de Energía.

7.3.4 Se identifican los riesgos de seguridad asociados con la pérdida de confidencialidad, integridad y/o disponibilidad de la información, y se identifican los dueños de los riesgos.	**Hallazgos identificados.**
	información, pero la misma fue aplicada. Por otra parte, se relaciona la valoración de las tres características con la valoración de las amenazas de seguridad y por ende genera una afectación en la nota que obtiene la amenaza del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se puede tomar como referencia el marco COBIT 5 para el diseño del proceso de gestión de riesgos del Instituto Nicaragüense de Energía.

7.3.5 Se analizan los riesgos de seguridad de la información y se determinan potenciales consecuencias, una probabilidad realista y los niveles.	**Hallazgos identificados.**
	Se analizan los riesgos de seguridad de la información y se determinan potenciales consecuencias, una probabilidad realista del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se puede tomar como referencia el marco COBIT 5, para el diseño del proceso de gestión de riesgos del Instituto Nicaragüense de Energía.
7.3.6 Se evalúan los riesgos para compararlos con los criterios previamente definidos y se priorizan para su tratamiento.	**Hallazgos identificados.**
	El proceso de evaluación de riesgo logra cumplir con este punto. Pues está incompleto en su desarrollo del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se recomienda definir un proceso formal para la gestión de riesgos de seguridad de la información. Se puede tomar como referencia el marco COBIT 5, para el diseño del proceso de gestión de riesgos del Instituto Nicaragüense de Energía.
7.3.7 El proceso de evaluación de riesgos de seguridad de la información se	**Hallazgos identificados.**
	hay un marco normativo que regule la ejecución de proceso de gestión de riesgos del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.

documentado.	Se puede tomar como referencia el marco COBIT 5 para el diseño del proceso de gestión de riesgos del Instituto Nicaragüense de Energía.
7.3.8 La organización define y aplica un proceso de tratamiento de riesgo para seleccionar las opciones de tratamiento.	**Hallazgos identificados.**
	El proceso aplicado define las posibles acciones de tratamiento de riesgos del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se recomienda definir un proceso formal para la gestión de riesgos de seguridad de la información. Se puede tomar como referencia el marco COBIT 5 para el diseño del proceso de gestión de riesgos del Instituto Nicaragüense de Energía.

7.3.9 Se determinan los controles que son necesarios para implementar las opciones de tratamiento seleccionadas. (con cualquier fuente)	**Hallazgos identificados.**
	El proceso aplicado define las posibles acciones de tratamiento de riesgos del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se recomienda definir un proceso formal para la gestión de riesgos de seguridad de la información. Se puede tomar como referencia el marco COBIT 5 para el diseño del proceso de gestión de riesgos del Instituto Nicaragüense de Energía.
7.3.10 Se comparan los controles con seleccionados con el Anexo A para evitar cualquier omisión.	**Hallazgos identificados.**
	existe un estatuto de aplicabilidad que justifique los controles e implantar, sin embargo, se utiliza como fuente de controles el Anexo A de la norma ISO 27001 del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se recomienda definir un proceso formal para la gestión de riesgos de seguridad de la información que involucre la gestión para el tratamiento de los riesgos del Instituto Nicaragüense de Energía.
7.3.11 Se genera el estatuto de aplicabilidad.	**Hallazgos identificados.**
	El proceso aplicado define las posibles acciones de tratamiento de riesgos del Instituto Nicaragüense de Energía

	Conclusiones y recomendaciones.
	Este documento justifica y define los controles que son aplicables a la norma y la justificación de cuáles son aplicables del Instituto Nicaragüense de Energía.
7.3.12 Se formula un plan de tratamiento de riesgos.	**Hallazgos identificados.**
	El proceso aplicado define las posibles acciones de tratamiento de riesgos del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se recomienda definir un proceso formal para la gestión de riesgos de seguridad de la información que involucre la gestión para el tratamiento de los riesgos. Se puede tomar como referencia el marco COBIT 5 para el diseño del proceso de gestión de riesgos del Instituto Nicaragüense de Energía.
7.3.13 Se obtiene la aprobación de los dueños de los riesgos para el plan de tratamiento y aceptación del riesgo residual.	**Hallazgos identificados.**
	El proceso aplicado define las posibles acciones de tratamiento de riesgos del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se recomienda definir un proceso formal para la gestión de riesgos de seguridad de la información que involucre la gestión para el tratamiento de los riesgos. Se puede tomar como referencia el marco COBIT 5 para el diseño del proceso de gestión de riesgos del Instituto Nicaragüense de Energía.
7.3.14 Se documenta el proceso de tratamiento de riesgos	**Hallazgos identificados.**
	El proceso aplicado define las posibles acciones de tratamiento de riesgos del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se recomienda definir un proceso formal para la gestión de riesgos de seguridad de la información que involucre la gestión para el tratamiento de los riesgos del Instituto Nicaragüense de Energía.
7.3.15 El Instituto	**Hallazgos identificados.**

Nicaragüense de Energía debe establecer objetivos en funciones y niveles relevantes.	existe una definición de objetivos de seguridad sólo de la política de seguridad de la información que se encuentra en borrador del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se recomienda elaborar la política de seguridad donde quede establecido formalmente los objetivos de seguridad de la información y la estrategia de alcance de dichos objetivos del Instituto Nicaragüense de Energía.
Nivel de riesgo expuesto – Planeación.	

Alto	Este tipo de riesgos deben ser minimizados del Instituto Nicaragüense de Energía, aunque esto suponga una inversión económica, de tiempo, recursos institucionales, entre otros, siempre y cuando los recursos asignados afecten la operativa o causen nuevos riesgos de otra índole.
Porcentaje de cumplimiento	

Ilustración 7 Porcentaje de cumplimiento Planificación "autoría propia"

7.4 Clausula Soporte.

Definición según la cláusula de la norma – Soporte.
Lo necesario para establecer, implementar, mantener y mejorar continuamente un SGSI, así como los requerimientos de recursos o competencias de las personas involucradas, conocimiento, comunicación y requisitos para la gestión de documentos donde se da más énfasis en el contenido en lugar del nombre del Instituto Nicaragüense de Energía.
Madurez Inicial.

Nivel de madurez general.
 Ilustración 8 Soporte. "autoría propia"
Situación evidenciada.
Hallazgos satisfactorios.

7.4.1 Recursos.	
7.4.2 INE determina y provee los recursos necesarios para el establecimiento, implementación, mantenimiento y mejora continua del SGSI.	**Hallazgos identificados.**
	Los recursos necesarios han sido identificados y establecidos, está en proceso de realizarse dicha actividad. Sin embargo, posee un procedimiento de presupuesto que asegura la asignación de los recursos necesarios en caso de que los mismos sean aprobados como parte del presupuesto del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Es indispensable que los responsables del SGSI consideren y definan todos los recursos necesarios para la implantación y operación del SGSI y que los mismos sean apoyados por la dirección del Instituto Nicaragüense de Energía.
7.4.3 Comunicación.	
7.4.4 El Instituto Nicaragüense de Energía ha determinado la necesidad de	**Hallazgos identificados.**
	existe un plan de comunicación sobre la seguridad del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.

establecer comunicaciones internas y externas.	En este punto se recomienda crear documentación formal del Instituto Nicaragüense de Energía (procedimiento, instructivo) en donde se defina el proceso de comunicación interna y externa en donde se incluya qué comunicar, cuando hacerlo, a quién comunicarlo, quién debe comunicarlo y el canal por el cuál la comunicación será realizada.
7.4.5 Información documentada.	
7.4.6 El SGSI incluye la información documentada según es requerida por el estándar ISO 27001 y aquella	**Hallazgos identificados.**
	se ha documentado la información que requiere el SGSI. Existen documentos en borrador que describen políticas, roles y responsabilidades, una matriz de evaluación de riesgos incompleta del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.

información que la organización considere como necesaria documentar y adicionar.	Es necesario formalizar y definir los procesos del área de seguridad y documentarlos formalmente estableciendo las políticas, normas, procedimientos, manuales, guías, formularios que deben cumplirse para el adecuado funcionamiento del área y cumplimiento de los objetivos del SGSI del Instituto Nicaragüense de Energía.
7.4.7 Creación y Actualización.	
7.4.8 Cuando se crea y actualiza información documentado del Instituto Nicaragüense de Energía asegura una adecuada identificación y descripción.	**Hallazgos identificados.**
	existe una política de gestión documental junto con un procedimiento que asegure esto del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Es necesario formalizar y definir los procesos del área de seguridad y documentarlos formalmente estableciendo las políticas, normas, procedimientos del Instituto Nicaragüense de Energía.
7.4.9 Control de información documentada.	
7.4.10 La información documentada requerida por el SGSI es	**Hallazgos identificados.**
	existe una política de gestión documental junto con u procedimiento que asegure esto del Instituto Nicaragüense de Energía.

controlada para asegurar que se encuentra disponible y en condiciones de uso.	**Conclusiones y recomendaciones.**
	Es necesario formalizar y definir los procesos del área de seguridad y documentarlos formalmente estableciendo las políticas, normas, procedimientos, manuales, guías, formularios que deben cumplirse para el adecuado funcionamiento del área y cumplimiento de los objetivos del SGSI del Instituto Nicaragüense de Energía.
7.4.11 El Instituto Nicaragüense de Energía posee actividades designadas (Según sea aplicable) para la distribución,	**Hallazgos identificados.**
	Está claramente definido que el director de TI Emite Disposiciones Internas, sin embargo, el proceso no está claramente documentado del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se requiere definir el procedimiento para el desecho de la documentación que ya ha cumplido el ciclo de vida y

obtención, acceso.	requiere ser eliminada del Instituto Nicaragüense de Energía.
7.4.12 El Instituto Nicaragüense de Energía contempla para estas actividades toda aquella documentación externa que es requerida para la planeación y operación del SGSI.	**Hallazgos identificados.**
	Existe una política de gestión documental junto con un procedimiento que asegure esto del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se recomienda definir los lineamientos en relación a la clasificación y etiquetado de la documentación de origen externo requerida para la planeación y operación del SGSI del Instituto Nicaragüense de Energía.
7.4.13 Nivel de riesgo expuesto.	
Alto	Este tipo de riesgos deben ser minimizados, aunque esto suponga una inversión económica, de tiempo, recursos institucionales, entre otros, siempre y cuando los recursos asignados no afecten la operativa o causen nuevos riesgos de otra índole del Instituto Nicaragüense de Energía.
Nivel de cumplimiento	

Ilustración 9 Porcentaje de cumplimiento Soporte "autoría propia"

7.5 Cláusula Operaciones.

Definición según la cláusula de la norma – Operaciones.
El Instituto Nicaragüense de Energía deben planificar, implementar y controlar los procesos necesarios para cumplir los requisitos de seguridad de la información se debe llevar a cabo valoraciones de riesgo de SI a intervalos planificados y la implementación de un Plan de Tratamiento de Riesgos de SI.

Ilustración 10 Operaciones "autoría propia"

Madurez N/E.	
Nivel de madurez general.	
Situación evidenciada.	
7.5.1 Planificación y control operativo.	
7.5.2 El Instituto Nicaragüense de Energía debe planificar, implementar y	**Hallazgos identificados.**
	Existe un proceso de control operativo de seguridad de la información del Instituto Nicaragüense de Energía.
7.5.3 El Instituto Nicaragüense de Energía debe de implementar los planes para lograr los objetivos planteados en seguridad de la información.	**Conclusiones y recomendaciones.**
	Se recomienda el diseño de un formalmente definido donde se puedan gestionar de una forma más clara todos los procesos involucrados en el SGSI y a partir de allí generar los procedimientos, manuales, guías, formularios necesarios, una vez comprendido el esquema de procesos del Instituto Nicaragüense de Energía.
	Hallazgos identificados
	Existe un proceso de control operativo de seguridad de la información del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Se recomienda el diseño formalmente definido donde se puedan gestionar de una forma más clara todos los procesos involucrados en el SGSI y a partir de allí generar los procedimientos, manuales, guías, formularios necesarios, una vez comprendido el esquema de procesos del Instituto Nicaragüense de Energía.

7.5.4 El Instituto Nicaragüense de Energía realiza evaluaciones de riesgo cuando ocurran	**Hallazgos identificados**
	Se aplican evaluaciones de riesgo en períodos muy largos.
	Conclusiones y recomendaciones.

cambios significativos o en intervalos planificados.	Se puede tomar como referencia el marco COBIT 5, el estándar ISO 27005. Se deben realizar evaluaciones de riesgos en intervalos debidamente planificados al menos durante dos veces al año o bien cuando ocurran cambios significativos del Instituto Nicaragüense de Energía.
7.5.5 El Instituto Nicaragüense de Energía conserva las evaluaciones de riesgo de forma documentada.	**Hallazgos identificados.**
	Se aplican evaluaciones de riesgo en períodos muy largos.
	Conclusiones y recomendaciones.
	Se puede tomar como referencia el marco COBIT 5, el estándar ISO 27005. Se deben realizar evaluaciones de riesgos en intervalos debidamente planificados al menos durante dos veces al año o bien cuando ocurran cambios significativos del Instituto Nicaragüense de Energía.
7.5.6 Tratamiento de los riesgos de seguridad de la información.	
7.5.7 El Instituto Nicaragüense de Energía debe de poner en práctica el plan de tratamiento de riesgos.	**Hallazgos identificados.**
	Se deben aplicar los planes de tratamiento de riesgos del Instituto Nicaragüense de Energía de acuerdo los estándares de la Auditoria.
	Conclusiones y recomendaciones.
	Se puede tomar como referencia el marco COBIT 5, el estándar ISO 27005.Se deben realizar evaluaciones de riesgos en intervalos debidamente planificados al menos durante dos veces al año o bien cuando ocurran cambios significativos del Instituto Nicaragüense de Energía.
Nivel de riesgo expuesto.	

Bajo	Este tipo de riesgos deben ser minimizados, aunque esto suponga una inversión económica, de tiempo, recursos institucionales, entre otros, siempre y cuando los recursos asignados afecten la operativa o causen nuevos riesgos de otra índole del Instituto Nicaragüense de Energía.

Ilustración 11 Porcentaje de cumplimiento de operaciones "autoría propia"

7.6 Cláusula Evaluación del desempeño.

Definición según la cláusula de la norma – Evaluación de desempeño.
Auditorías internas y revisión por la dirección de métodos claves de la revisión del rendimiento del SGSI herramientas para su mejora continua del Instituto Nicaragüense de Energía.
Madurez Inicial.
Nivel de madurez general.

Ilustración 12 Evaluación del desempeño "autoría propia"

Situación evidenciada.	
Hallazgos no satisfactorios.	
7.6.1 Monitoreo, medición, análisis y evaluación.	
7.6.2 El Instituto Nicaragüense de Energía debe de evaluar el rendimiento y la eficacia de la SGSI.	**Hallazgos identificados.**
	se aplican evaluaciones de seguridad y al no existir un SGSI del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Por lo que es necesario contar con: los métodos paran monitorizar, medir, analizar y evaluar, cuando sea aplicable, para asegurar unos resultados adecuados. Definir cuándo deberán ser realizadas las monitorizaciones y mediciones. Quién deberá monitorizar y medir. Cuando deberán ser analizados y evaluados (rangos de normalidad y anomalía) los resultados de la monitorización y medición del Instituto Nicaragüense de Energía
7.6.3 Auditorías internas.	
7.6.4 El Instituto Nicaragüense de Energía debe de realizar Auditorías Internas.	**Hallazgos identificados.**
	Los procesos de autoevaluación por medio de auditorías internas del Instituto Nicaragüense de Energía se aplican en períodos largos.
	Conclusiones y recomendaciones.
	Se recomienda elaborar un programa de auditoría para el SGSI y el procedimiento para autoevaluación de auditoría interna del Instituto Nicaragüense de Energía.
	Hallazgos identificados.

7.6.5 Revisión de derechos de acceso de usuarios.	De acuerdo con la sesión desarrollada con el área de Infraestructura de la Entidad, se identificó que no está actualizada la Gestión de la información de autenticación secreta de los usuarios, que permita controlar la asignación de la información de autenticación secreta a través de un proceso de gestión formal del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.

	Se recomienda definir un proceso formal para la gestión de accesos y privilegios en donde se establezca el mecanismo para la revisión de los accesos y privilegios, la figura responsable de la ejecución del mantenimiento y la frecuencia para la revisión adecuada de los usuarios en las aplicaciones institucionales del Instituto Nicaragüense de Energía.
Alto	Este tipo de riesgos deben ser minimizados, aunque esto suponga una inversión económica, de tiempo, recursos institucionales, entre otros, siempre y cuando los recursos asignados no afecten la operativa o causen nuevos riesgos de otra índole del Instituto Nicaragüense de Energía.
Nivel de cumplimiento	

Ilustración 13 Porcentaje de cumplimiento Evaluación del desempeño

7.6.6 Control de acceso de Aplicaciones.	
	Hallazgos identificados.

7.6.7 Restricción de acceso a la información.	De acuerdo con la sesión desarrollada con el área de Infraestructura de la Entidad, se identificó que se cuentan con controles para garantizar la seguridad de las aplicaciones y bases de datos del Instituto Nicaragüense de Energía.

	Conclusiones y recomendaciones.
	Por lo tanto, se recomienda de acuerdo con controles anteriores, definir un proceso formal para el mantenimiento y revisión frecuente de accesos a las aplicaciones del Instituto Nicaragüense de Energía.
7.6.8 Procedimientos seguros de inicio de sesión.	**Hallazgos identificados.**
	De acuerdo con la sesión desarrollada con el área de Infraestructura de la Entidad, se identificó que no se cuentan con controles para garantizar la seguridad de las aplicaciones y bases de datos del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	Por lo tanto, se recomienda de acuerdo con controles anteriores, definir un proceso formal para el mantenimiento y revisión frecuente de accesos a las aplicaciones del Instituto Nicaragüense de Energía.
	Hallazgos identificados.
7.6.9 gestión de contraseñas.	De acuerdo con la sesión desarrollada con el área de Infraestructura de la Entidad, se identificó que se cuentan con controles para garantizar la gestión de contraseñas de las aplicaciones, bases de datos, sistemas operativos y usuarios finales del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones
	Por lo tanto, se recomienda de acuerdo con controles anteriores, definir un proceso formal de contraseñas que contenga: identificadores de usuario y contraseña individuales para mantener la rendición de cuentas; permitir a los usuarios cambiar sus propias contraseñas e incluir un procedimiento de confirmación de contraseñas del Instituto Nicaragüense de Energía.
7.6.10 Uso de programas y utilidades privilegiadas.	**Hallazgos identificados.**
	De acuerdo con la sesión desarrollada con el área de Infraestructura de la Entidad, se identificó que existen controles que se implementan para evitar que se instalen programas y utilidades que pueden atentar a la seguridad de la información del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.

	Se recomienda elaborar una política que defina el uso de programas y utilidades privilegiadas. Verificar que contenga las siguientes consideraciones: utilización de los procedimientos de identificación, autenticación y autorización de los servicios; segregación de los programas de utilidad del software de aplicaciones; limitación de la utilización de programas de utilidad para el número mínimo necesario de confianza; autorización para el uso especial de los programas de servicios; registro de todo el uso especial de los programas de servicios del Instituto Nicaragüense de Energía.
7.6.11 Control de acceso al código fuente del programa.	**Hallazgos identificados.**
	Se hace uso de usuarios genéricos y además no se cuenta con una política de uso controlado del código fuente de las aplicaciones. De igual manera, hay un cifrado para poder proteger la información en lo referente a uso, modificación, eliminación del Instituto Nicaragüense de Energía.
	Conclusiones y recomendaciones.
	documentación para controlar el acceso a este tipo de bibliotecas de programas fuente a fin de reducir las posibilidades de corrupción de programas de ordenador del Instituto Nicaragüense de Energía: El código fuente del programa y de las bibliotecas de código del programa deben ser manejados de acuerdo a los procedimientos establecidos. El personal de apoyo debe tener acceso sin restricciones a las bibliotecas de programas fuente.
7.6.12 Equipo.	
7.6.13 Instalación y protección de equipos.	**Hallazgo identificado.**
	De acuerdo con la revisión realizada se denotan carencias en la instalación y protección de los equipos. En la visita efectuada al centro de datos principal del INSTITUTO NICARAGUENSE DE ENERGIA (INE), los equipos no se encuentran protegido adecuadamente,

	prohibiciones de acceso a los sitios con equipos sensibles.
	Conclusión y Recomendación.

	Se recomienda evaluación en el área de la infraestructura tecnológica y tomar las medidas correctivas bajo un plan de acción que logre garantizar la protección de activos críticos de la institución.
7.6.14 Servicios de soporte.	**Hallazgo identificado.**
	De acuerdo con la revisión realizada en el área de infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), se encontraron deficiencias en el mantenimiento y revisión de los equipos generales y principales ya que no existe un plan de mantenimiento o normativa que obligue a realizar acciones preventivas con el fin de prevenir riesgo de pérdida de información o daños a la infraestructura de TI. Existe un programa de mantenimiento, pero no está actualizado.
	Conclusión y Recomendación.
	Se recomienda establecer el diseño de un proceso formal que defina específicamente los servicios de soporte que se debe seguir de acuerdo al INE con el cumplimiento lo los mantenimientos preventivos con el fin de asegurar los equipos y la información que procesan.
7.6.15 Seguridad en el cableado.	**Hallazgo identificado.**
	De acuerdo con la revisión realizada en el área de infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), se denotan deficiencias hay espacios que si cuentan con una separación adecuada entre los cables de energía y de comunicación hay una instalación adecuada sin embargo hay dependencias que carecen de algunos aspectos básicos como acceso controlado a los paneles de conexión así mismo se cuenta con una política de protección de cableado con los aspectos básico de seguridad física y de entorno.
	Conclusión y Recomendación.
	Se recomienda definir un procedimiento que establezca en todas las dependencias de INE la necesidad de controlar con seguridad el cableado y que al menos cumpla con los siguiente:

	✓ El cableado de la energía y telecomunicaciones que transporta los datos se encuentre protegido de intercepción, interferencia y daño. ✓ La línea de energía y telecomunicaciones debe estar bajo tierra o sujeta a protección alternativa adecuada.
7.6.16 Mantenimiento de Equipos.	**Hallazgo identificado.**
	De acuerdo con la revisión en el área de infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), se denota que existe un programa de mantenimiento que no tiene fecha definida de ejecución. Dentro de las políticas y norma se define la frecuencia para la realización de mantenimiento por lo que queda a discreción de cada unidad.
	Conclusión y Recomendación.
	Se recomienda definir un proceso formal que establezca los lineamientos para el mantenimiento de los equipos y que sea extensivo y de aplicabilidad obligatoria a todas las unidades del INE.
7.6.17 Retiro de activos.	**Hallazgo identificado.**
	De acuerdo con la revisión en el área de infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), se denota que no existe una política que brinde los lineamientos a seguir para el estricto control sobre el retiro de activos de la organización la seguridad física aplica un acta de remisión, entrega y salida de los equipos con las respectivas firmas de los involucrados.
	Conclusión y Recomendación.
	Se recomienda elaborar una política donde indique que los empleados y los usuarios externos que tiene la autoridad para permitir retirar activos fuera de las instalaciones estos deben ser identificados: los plazos para la eliminación de los activos se debe establecer su verificación y cumplimiento apropiado, los activos deben registrarse cuando son retirados fuera del sitio y se registra cuando se devuelve.
7.6.18 Seguridad en el equipo.	**Hallazgo identificado.**
	existe la definición y aplicación de este control dentro de los actuales procesos de la gestión de la seguridad de la

	información del INSTITUTO NICARAGUENSE DE ENERGIA (INE).
	Conclusión y Recomendación.
	Se recomienda definir un proceso formal que norme los lineamientos a ser aplicados a los activos que salen de las instalaciones teniendo en cuenta los diferentes riesgos de trabajar en la organización, los equipos y medios de comunicación que salen de las instalaciones deben quedar sin vigilancia en lugares públicos, las instrucciones del fabricante para la protección de equipos se deben observar en todo momento.
7.6.19 Equipo	**Hallazgo identificado.**
de usuario desatendido.	De acuerdo con la sesión obtenida del área de infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), en la actualidad se carece de un procedimiento que brinde lineamientos para la seguridad de los equipos no atendidos.
	Conclusión y recomendación.
	Se recomienda lo siguiente: ✓ Mediante el diseño de un plan de sensibilización concientizar a los usuarios el hábito de bloquear su equipo, dispositivo de uso personal en la institución cuando no esté en uso. ✓ Aplicar el bloqueo automático de las sesiones de los equipos cuando el usuario no esté usando el mismo por más de 30 segundos siempre y cuando el servicio que brinda así lo permita o de lo contrario buscar una solución que se adapte a su tiempo de uso. ✓ Crear campañas de sensibilización luego de las nuevas políticas aprobadas.
7.6.20 Política de escritorio y pantalla limpia.	**Hallazgo identificado.**
	De acuerdo con la sesión obtenida en el área de infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), actualmente se carece de una política de escritorio limpio para papeles y medios de almacenamiento removibles y una política de pantalla limpia para las instalaciones de procesamiento de información.
	Conclusión y Recomendación.

	Se recomienda definir lo siguiente: ✓ Por medio del diseño de un programa de sensibilización, mostrar las debilidades de la organización y los riesgos de incumplir con este control. Una vez creada la conciencia, mediante el programa de sensibilización disponer a crear una cultura en donde se comprometa toda la organización en cumplir con la campaña de escritorio y pantalla limpia de información. ✓ Definir dentro de la política de seguridad de la información la adopción de un escritorio limpio de información y pantalla limpia de información. Realizar revisiones periódicas sobre el cumplimiento de los funcionarios con la política de escritorio y pantalla limpia de información.
Nivel de riesgo expuesto	Este tipo de riesgo debe ser minimizado, aunque esto suponga una inversión económica de tiempo y recursos institucionales siempre y cuando los recursos no afecten su operación.
Medio	La minimización de este tipo de riesgo es de suma importancia para garantizar la continuidad y la seguridad de las operaciones del Instituto Nicaragüense de Energía (INE). Aunque pueda implicar una inversión económica considerable, así como la asignación de tiempo y recursos institucionales, es crucial mantener un equilibrio para asegurar que estas medidas no afecten negativamente la funcionalidad del INE. Por lo tanto, es fundamental realizar una evaluación exhaustiva de los recursos disponibles y de las acciones necesarias para mitigar los riesgos identificados, con el fin de evitar cualquier repercusión adversa en la operación del instituto.

7.7 Clausula Mejora.

Definición según el dominio de la norma – Mejora.

Para cumplir con este dominio de la norma ISO 27002, dentro de la mejora de red se incluyen los sistemas operativos, infraestructura, aplicaciones de negocio, aplicaciones estándar o de uso generalizado, servicios y aplicaciones desarrolladas por los usuarios. El diseño e implantación que sustentan los procesos de negocio pueden ser cruciales para la seguridad. Los requisitos de seguridad deberían ser identificados y consensuado previamente al desarrollo e implantación, todos los requisitos de seguridad se deben identificar en la fase de un proyecto y ser justificado, aceptado y documentado como parte del proceso completo.
Madurez Optimizado.

Ilustración 14 Mejora "autoría propia"

Situación evidenciada.	
Hallazgo no satisfactorio.	
7.7.1 Clausula A 12 Procedimiento Operaciones y Responsabilidades.	
7.7.2 Documentación de procedimientos operacionales.	**Hallazgos identificados.**
	De acuerdo a la sesión efectuada con el área de infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), existen procedimientos documentados para las actividades asociadas con las instalaciones de comunicaciones y de procesamiento de información, respaldo, mantenimiento de equipos manejo de medios, utilización de correos sin embargo los documentos carecen de firmas de aprobación de una persona responsable o encargado de revisarlo, en el caso de los respaldo se especifica la herramienta que se usa para ejecutar el procedimiento, hora que se realiza y que es lo se respalda

	El llenado de bitácoras de control y carece indicaciones de notificación que se recibe cuando los respaldos son realizados de manera exitosa el documento de mantenimiento de equipos y políticas de acceso físico esta desactualizado. existe un procedimiento definido de

	bitácoras de seguridad para revisar de manera constante y segura los cambios.
	Conclusión y Recomendación.
	Actualmente el INSTITUTO NICARAGUENSE DE ENERGIA (INE), maneja una definición formal de los procesos lo que conlleva a las carencias de la definición de procedimientos a nivel operativo y desarrollo de manuales instructivo, se recomienda definir y documentar los procesos del área de TI y definición de los procesos operativos.
7.7.3 Gestión de activos.	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida del área de infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), actualmente se carece de un procedimiento que brinde lineamientos para el debido control de cambios.
	Conclusión y Recomendación.
	Se recomienda la elaboración de procedimientos que establezcan las buenas prácticas para el adecuado control de cambios los cuales deben contener identificación y registro de cambios, planificación y pruebas, la evaluación de los impactos potenciales, la comprobación de que se cumplen los requisitos de seguridad de la información, comunicación de los detalles de cambios a todas las personas pertinentes incluido los procedimientos y responsabilidades para abortar y recuperar cambios fallidos y acontecimientos imprevistos.
7.7.4 Gestión de la capacidad.	**Hallazgos identificados.**
	De acuerdo con la revisión efectuada y sesión obtenida con las diferentes áreas del INSTITUTO NICARAGUENSE DE ENERGIA (INE), no existe un plan documentado para la gestión y la capacidad del desempeño de la arquitectura tecnológica.
	Conclusión y Recomendación.

	Se recomienda definir un plan formal para la gestión del desempeño y la capacidad de la plataforma tecnológica el cuál sea periódicamente revisado y monitoreado, que gestione la capacidad y el desempeño actual de la plataforma, la capacidad y desempeño futuro, la disponibilidad de recursos de TI. Se puede tomar como referencia para este control el marco COBIT 5 específicamente el proceso de Administrar el desempeño y la Capacidad.
7.7.5 Separación de los ambientes de desarrollo, pruebas y operación.	**Hallazgos identificados.**
	De acuerdo con la revisión efectuada y sesión obtenida con las diferentes áreas existe una política que indique la debida separación de los ambientes de desarrollo, pruebas y operación.
	Conclusión y Recomendación.
	Se recomienda elaborar una política que contenga las siguientes consideraciones: las normas para la transferencia de software desde el desarrollo hasta el estado de funcionamiento deben ser definidas y documentadas; el desarrollo y software de operación deben ejecutarse en diferentes procesadores de ordenador y en diferentes dominios o directorios.
7.7.6 Clausula Protección de software Malicioso.	
7.7.7 Controles contra software malicioso.	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área de Infraestructura actualmente el INSTITUTO NICARAGUENSE DE ENERGIA (INE), maneja controles para la prevención de malware. Los equipos manejan el Antivirus ESET licenciado. Esto es aplicado a todas las dependencias de INE. Adicionalmente se cuentan con IPS. Sin embargo, existe una política formal de protección contra los riesgos asociados a la obtención de archivos y software por redes externas o cualquier otro medio, indicando las medidas protectoras a adoptar.
	Conclusión y Recomendación.
	Se recomienda la elaboración de política de controles de detección, prevención y recuperación para proteger contra el malware, estos se deben implementar, junto con el conocimiento del usuario correspondiente. Verificar que contenga: el establecimiento de una política oficial que prohíbe el uso de software no autorizado.
7.7.8 Clausula Respaldo.	
	Hallazgos identificados.

7.7.9 Respaldo de información.	De acuerdo con la revisión efectuada en el INSTITUTO NICARAGUENSE DE ENERGIA (INE), existe una Política de Respaldo de información (Bases de Datos y Sistemas Operativos), sin embargo, está desactualizada y carece de firmas de aprobación, persona responsable de revisarlo, persona responsable de elaborarlo, control de versiones, tipos de respaldos que se realizan, ✓ especifica el llenado de bitácoras de respaldo. ✓ indica mecanismos con el cuál se respalda. ✓ se indica respecto a la notificación que se recibe cuándo los respaldos se realizaron de manera exitosa.
	Conclusión y recomendación.

	Se recomienda que la política de Respaldo incluya dentro de sus lineamientos: registros precisos y completos de las copias de seguridad y procedimientos de restauración documentados se deben producir; la medida (por ejemplo, copia de seguridad completa o diferencial) y la frecuencia de las copias de seguridad debe reflejar los requerimientos de negocio de la organización, los requisitos de seguridad de la información en cuestión y la criticidad de la información a la continuación del funcionamiento de la organización; las copias de seguridad se deben almacenar en una ubicación remota, a una distancia suficiente para escapar de cualquier daño de un desastre en el sitio principal; la información de copia de seguridad se debe dar un nivel apropiado de protección física y ambiental.
7.7.10 registro de eventos.	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área de Infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), actualmente se tienen activas todas las bitácoras o pistas de auditoría. Sin embargo, no existe un procedimiento que indique la configuración adecuada de pistas de auditoría que siempre debe estar configurada.
	Conclusión y recomendación.

	Se recomienda la definición de un procedimiento que indique la configuración adecuada de pistas de auditoría, que contenga: las actividades del Instituto Nicaragüense de Energía; las fechas, horarios y detalles de los eventos clave, por ejemplo, iniciar sesión y desconectarse; la identidad del dispositivo mediante el su dirección Mac o ir del dispositivo o la ubicación si es posible y el identificador; los registros de intentos de acceso a la red de éxito y rechazadas; registros de datos con éxito y rechazadas, y otros intentos de acceso a los recursos; los cambios en la configuración del Firewall; el uso de los privilegios; el uso de las utilidades y las aplicaciones; los archivos accedidos y el tipo de acceso; direcciones y protocolos de red; las alarmas planteadas por el control de acceso; la activación y desactivación de protección, como los antivirus y sistemas de detección de intrusos; los registros de las transacciones realizadas por los usuarios en las aplicaciones.
7.7.11 Protección de registro de información.	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área de Infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), estos son almacenados por el responsable de la gestión del controlador de dominio. Sin embargo, nos indican que existe un documento que indique los procedimientos que deben realizarse para cumplir con este control.

	Conclusión y recomendación.
	Se recomienda la definición de procedimientos que indiquen los lineamientos para protegerse contra cambios no autorizados a la información de registro y los problemas operacionales con la función de registro, incluyendo; las modificaciones de los tipos de mensajes que se registran.
7.7.12 Registro de administrador y operador.	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área de Infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), cada usuario cuenta un identificador y acceso único. Actualmente se encuentran habilitadas todas las pistas de auditoria para llevar el control de bitácoras según las cuentas de cada usuario. Sin embargo, existe documentado que brinde los lineamientos que deben cumplir para implementar y monitorear este control.
	Conclusión y recomendación.
	Se recomienda la definición de un procedimiento que brinde las pautas para garantizar que las actividades del administrador de red, son registradas y los registros protegidos y regularmente revisados.

7.7.13 Sincronización de reloj.	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida del INSTITUTO NICARAGUENSE DE ENERGIA (INE), se evidencia un servidor NTP que sincroniza todos los "time" de todos los servidores institucionales. Las instituciones toman el time de cada uno de los servers. Sin embargo, existe ninguna normativa que indique los lineamientos correspondientes a este control, para garantizar que se cumpla.
	Conclusión y recomendación.
	Se recomienda la definición de procedimientos que garanticen que los Requerimientos externos e internos para la representación del tiempo, sincronización y precisión deben ser cumplidos y documentados.
7.7.14 Clausula Control de la red del Instituto Nicaragüense de Energía.	
7.7.15 Configuración de red.	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área de Infraestructura y con las visitas realizadas al INSTITUTO NICARAGUENSE DE ENERGIA (INE), existe una lista de software autorizado. existe una política que brinde la estandarización de softwares permitidos. Algunos usuarios cuentan con permisos de administrador, implicando un riesgo de instalación de software licenciado para la integridad, confidencialidad y disponibilidad de la información.
	Conclusión y recomendación.
	Se recomienda aplicar el procedimiento de software autorizado aplicado por el área de Seguridad en todas las dependencias del INE. Se recomienda realizar evaluaciones periódicas para verificar la instalación de programas únicamente autorizados.
7.7.16 Clausula Gestión de vulnerabilidad técnica.	
7.7.17 Gestión de vulnerabilidad técnica.	**Hallazgos identificados.**
	De acuerdo con la revisión efectuada con el área de Infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), existe una normativa que indique el cumplimiento de análisis periódicos de vulnerabilidades de la red del Instituto. Nunca se han realizado estas
	Conclusión y recomendación
	Se recomienda definir un proceso formal que gestione la ejecución de pruebas de vulnerabilidades a la plataforma y activos de información del INE de forma periódica, con el
	Hallazgos identificados.

7.7.8 Restricción en la instalación de software.	De acuerdo con la sesión obtenida con el área de Infraestructura y revisiones efectuadas a las otras áreas del INSTITUTO NICARAGUENSE DE ENERGIA (INE), se concluyó lo siguiente. Existen lineamientos que deben cumplirse por parte del usuario final para no instalar software no autorizado, esto se hace mediante el antivirus ESET, a través del Active Directory. Sin embargo, existen usuarios en Tecnología con perfil administrador que pueden incumplir con esta política, dada la falta de monitoreo periódico a los equipos.
	Conclusión y recomendación.
	Se recomienda aplicar el mismo procedimiento que se ejecuta en oficinas centrales del INE sobre la gestión de software autorizado, para todas las dependencias de la misma, esto sin excepción alguna. Actualmente esto es
7.7.19 Clausula Consideraciones de Auditoria de red.	
7.7.20 Control	**Hallazgos identificados.**
de Auditoria de Red.	De acuerdo con la sesión obtenida con el área de Infraestructura y revisión de evidencias se concluyó lo siguiente: ✓ Si se realizan evaluaciones de seguridad de acuerdo con los requisitos de los entes reguladores que le aplican al INSTITUTO NICARAGUENSE DE ENERGIA INE, además ✓ con la normativa de control interno (políticas y normas de seguridad de TI). Sin ✓ embargo, existe una práctica de Auditoría Externa ✓ para obtener una opinión independiente de seguridad de la información de la Entidad. ✓ Si se define un programa de auditoría. Esto se hace anualmente e incluye dentro del alcance la planificación en el ámbito de seguridad. ✓ Antes de efectuar las auditorías de seguridad, se realiza siempre un aviso al auditado, y además en los casos en los que se desarrolla a infraestructuras críticas se aplican en horarios fuera de las labores diarias y existe toda una coordinación con las áreas responsables. ✓ Como apoyo a las auditorías de seguridad y otras, se utilizan marcos de referencias y normas internacionales sobre las buenas prácticas tales como la ISO27001-27002, COBIT 5, entre otros. ✓ Semestralmente y anualmente se realizan seguimientos sobre los hallazgos emitidos.

	Conclusión y recomendación.
	Se recomienda la definición de procedimientos que indiquen la manera segura de realizar auditorías a las redes de computadoras y las actividades relacionadas con la verificación de los sistemas operativos en el Instituto Nicaragüense de Energía (INE).
Nivel de riesgo expuesto.	
Medio	Este tipo de riesgos deben ser minimizados, aunque esto suponga una inversión económica, de tiempo, recursos institucionales, entre otros, siempre y cuando los recursos asignados no afecten la operativa o causen nuevos riesgos de otra índole.
Porcentaje de cumplimiento.	

Ilustración 15 Porcentaje de cumplimiento de la cláusula mejora "autoría propia.

7.8 Clausula Seguridad en las Comunicaciones.

Definición según el dominio de la Cláusula – Seguridad en las Comunicaciones.
Para cumplir con este dominio de la norma ISO 27002, Garantizar que los eventos y debilidades en la seguridad de red asociados que se comuniquen de modo que se puedan realizar acciones correctivas oportunas. Se debería establecer el informe formal de los eventos y de los procedimientos de escalada. Todos los empleados, contratistas y terceros deberían estar al tanto de los procedimientos para informar de los diferentes tipos de eventos y debilidades que puedan tener impacto en la seguridad de los activos del INSTITUTO NICARAGUENSE DE ENERGIA (INE).
Madurez Repetible.
Nivel de madurez general.

Ilustración 16 Seguridad en las Comunicaciones" Autoría propia".

situación evidenciada.	
Hallazgos no satisfactorios.	
7.8 Clausula Gestión de seguridad en red.	
7.8.1 **Controles de red.**	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el Área de Infraestructura de la red del INSTITUTO NICARAGUENSE DE ENERGIA (INE), no existen procedimientos que indiquen los controles de seguridad aplicados a la red. Se cuenta con un esquema de seguridad por ejemplo para el acceso a la red cada usuario debe disponer de su cuenta para acceder por lo que ningún tercero puede estar accediendo salvo se realice el proceso de habilitación de permisos.

	Conclusión y recomendación.
	Se recomienda la definición de una política de redes que contenga: las responsabilidades y los procedimientos para la gestión de equipos de red; indicando que la responsabilidad operativa de las redes debe ser separado de las operaciones de computadora en su caso. Además, deben establecerse controles para garantizar la confidencialidad e integridad de los datos que pasan a través de redes públicas o sobre las redes inalámbricas y para proteger la información y aplicaciones conectadas.
7.8.2 **Seguridad de los servicios de red.**	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el Área de Infraestructura el servicio de red del INSTITUTO NICARAGUENSE DE ENERGIA (INE), se encuentra definido y diseñado con los esquemas de seguridad requeridos y necesarios para la protección de la información institucional. Sin embargo, no existe una política de telecomunicaciones que indique la configuración a nivel de equipos que se encuentra definida para garantizar la comunicación eficiente y redundante de las plataformas de redes.
	Conclusión y recomendación.
	Se recomienda la definición de una política de redes que contenga: las responsabilidades y los procedimientos para la gestión de equipos de red; indicando que la responsabilidad operativa de las redes debe ser separado de las operaciones de computadora en su caso. Además, deben establecerse controles para garantizar la confidencialidad e integridad de los datos que pasan a través de redes públicas o sobre las

	redes inalámbricas y para proteger las aplicaciones conectados; llevar un registro y el seguimiento adecuados para permitir la grabación y detección de acciones que pueden afectar o son relevantes para la seguridad de la información.
7.8.3 Clausula Transferencia de información.	
7.8.4 Segregación en redes.	**Hallazgos identificados.**
	De acuerdo a la revisión efectuada no existe una política de seguridad informática del INSTITUTO NICARAGUENSE DE ENERGIA (INE), que brinde los lineamientos para la transferencia o intercambio de información en los canales de comunicaciones.
	Conclusión y recomendación.
	Se recomienda mejorar la política de redes que contenga: las responsabilidades y los procedimientos para la gestión de equipos de red; indicando que la responsabilidad operativa de las redes debe ser separado de las operaciones de computadora en su caso. Además, deben establecerse controles para garantizar la confidencialidad e integridad de los datos que pasan a través de redes públicas o sobre las redes inalámbricas y para proteger las aplicaciones conectados; llevar un registro y el seguimiento adecuados para permitir la grabación y detección de acciones que pueden afectar o son relevantes para la seguridad de la información en el INSTITUTO NICARAGUENSE DE ENERGIA.
7.8.5 Transferencia de información	
7.8.6 Acuerdo en la transferencia ha de información.	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área de Infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), la transferencia de Información con terceros siempre es gestionada de acuerdo con la cláusula de confidencialidad que se firma entre las partes. Dicha cláusula dispone todos los lineamientos en los que se compromete el tercero para el trato de la información de la Entidad.
	Conclusión y recomendación.
	Se recomienda definir en la política y norma de seguridad informática los lineamientos para el intercambio o transferencia de información a partir de los canales de comunicación institucionales con el fin de proteger la

	información transferida sobre cualquier intercepción, copia, modificación, mal enrutamiento o destrucción de la misma y asegurar la confidencialidad de la información de acuerdo con su clasificación y la integridad, disponibilidad y repudio sobre la misma.
7.8.7 Mensajería electrónica	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área de Infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), actualmente se tienen lineamientos definidos para el uso de mensajería electrónica.
	Conclusión y recomendación.
	Se recomienda definir dentro de la política de seguridad los lineamientos necesarios para la utilización del canal de mensajería electrónica que dispone la Institución actualmente. Es indispensable normar el tipo de información que se puede compartir por este canal de comunicación, el alcance sobre el uso que se le da a la herramienta, entre otros.
7.8.8 Requisitos ISO 27001:2013 Seguridad en las Comunicaciones.	
	Hallazgo identificado.
	De acuerdo con las diferentes sesiones obtenidas con las áreas de trabajo del INSTITUTO NICARAGUENSE DE ENERGIA (INE), el manejo de la confidencialidad es adoptado en todo momento, especialmente en el trato con terceros. El incumplimiento de alguna de las cláusulas de confidencialidad trae consigo efectos legales para quién se responsabilice del incumplimiento.
	Conclusión y recomendación
	Se recomienda definir dentro de la política de seguridad los lineamientos necesarios para la utilización del canal de mensajería electrónica que dispone la Institución actualmente. Es indispensable normar el tipo de información que se puede compartir por este canal de comunicación, el alcance sobre el uso que se le da a la herramienta, entre otros.
Medio	El riesgo debe ser reducido y valorar la aplicación de controles adecuados para minimizar el riesgo. Los controles a emplear deben ajustarse al presupuesto del Instituto Nicaragüense de Energía.

Ilustración 17 Porcentaje de cumplimiento de Seguridad en las Comunicaciones "autoría propia"

7.9 Cláusula Adquisición, Desarrollo y Mantenimiento de la red.

Para cumplir con este dominio se sustenta de la norma ISO 27002, el INSTITUTO NICARAGUENSE DE ENERGIA (INE), Se debe de garantizar que la seguridad es parte integral de la información. Dentro del instituto la formación se incluye las infraestructuras, aplicaciones de negocio, aplicaciones estándar o de uso generalizado, servicios y aplicaciones desarrolladas por los usuarios. El diseño e implantación de información que sustentan los procesos de negocio pueden ser cruciales para la seguridad. Los requisitos de seguridad deberían ser identificados y consensuados previamente al desarrollo y/o implantación de información. Todos los requisitos de seguridad deberían identificarse en la fase de recolección de requerimientos de los requisitos de un proyecto y ser justificados, aceptados y documentados como parte del proceso completo.
Madurez Optimizado.
Nivel de madurez general.

Ilustración 18 Adquisición, Desarrollo y Mantenimiento de la red "autoría propia"

Adquisición, Desarrollo y Mantenimiento de la red "autoría propia"

Situación evidenciada.	
Hallazgos no satisfactorios.	
7.9.1 Requerimientos de seguridad de red.	
7.9.2 Análisis y especificación de los requerimientos de seguridad.	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área de sistemas del INSTITUTO NICARAGUENSE DE ENERGIA se identificó que existe una política de desarrollo documentada. Cada analista utiliza su propia metodología de desarrollo de software PHP. El único control de seguridad que se toma en los requerimientos de desarrollo es el de detallar los usuarios que pueden acceder a la información o al cambio.
	Conclusión y recomendación.
	Se recomienda se defina dentro de la etapa de análisis de requerimientos para acceder a la información, una etapa de requerimientos ligados con la seguridad de la información y en donde se involucre al Saborea de Seguridad en TI como asesora y experta en el tema.
7.9.3 Aseguramiento de servicios de	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área del INSTITUTO NICARAGUENSE DE ENERGIA (INE), se verifico que no se maneja una guía que contenga niveles de confianza, autenticación, procesos de autorización de usuarios.
	Conclusión y recomendación.

aplicación en redes públicas.	Se recomienda generar una campaña para los empleados en la cual se definan buenas prácticas para proteger la integridad de la información que se maneja en los diferentes sitios web, así como la implementación de controles criptográficos y firma digital de ser posible en todos los la web de la institución.
7.9.4 **Protección de transacciones de servicios de aplicación.**	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área del INSTITUTO NICARAGUENSE DE ENERGIA (INE), identificados que utilizan certificados SSL y protocolos de servicio HTTP, de igual manera se manejan políticas transaccionales para garantizar la integridad de la información.
	Conclusión y recomendación.
	Se recomienda generar una campaña para los empleados en la cual se definan buenas prácticas para proteger la integridad de la información que se maneja en los diferentes sitios web, así como la implementación de controles criptográficos y firma digital de ser posible en toda la web de la institución.
7.9.5 Seguridad en el proceso de desarrollo y soporte.	
7.9.6 **Política de desarrollo seguro.**	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área del INSTITUTO NICARAGUENSE DE ENERGIA (INE), durante fase del ciclo de vida de los desarrollos y se incorporan pruebas de seguridad como parte de las prácticas de desarrollo seguro.
	Conclusión y recomendación.
	Se recomienda definir dentro de la metodología de desarrollo, involucrar en todas las fases del CVDS la gestión de la seguridad de la información con apoyo, asesoramiento y fiscalización del Sub área de Seguridad en TI.
7.9.7	**Hallazgos identificados.**
	De acuerdo a la sesión obtenida con el área del INSTITUTO NICARAGUENSE DE ENERGIA (INE), se verifico que cada cambio solicitado al área es debidamente documentado y aprobado por la dirección. Sin embargo, no existe un

Procedimientos de control de cambios.	procedimiento de control de cambios documentado formalmente.
	Conclusión y recomendación
	Se recomienda definir dentro de la metodología de desarrollo, involucrar en todas las fases del CVDS la gestión de la seguridad de la información con apoyo, asesoramiento y fiscalización del área de Seguridad. En este caso en el proceso de gestión de cambios es indispensable.
7.9.8 **Revisión técnica de aplicaciones después de cambios a la plataforma operativa.**	**Hallazgos identificados.**
	De acuerdo a la sesión obtenida del INSTITUTO NICARAGUENSE DE ENERGIA (INE), se verifico que cuando se realizan cambios en la plataforma tecnológica se realizan pruebas funcionales sin embargo se tiene documentadas estas pruebas en una política formal.
	Conclusión y recomendación.
	Se recomienda definir dentro de la metodología de desarrollo, involucrar en todas las fases del CVDS la gestión de la seguridad de la información con apoyo, asesoramiento y fiscalización del área.
7.9.9 **Principios de ingeniería de red.**	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área y revisión obtenida a nivel de las normas de seguridad informática del INSTITUTO NICARAGUENSE DE ENERGIA (INE), no se tienen definidos los lineamientos para los principios de ingeniería de computación.
	Conclusión y recomendación.
	Se recomienda incluir en la política de seguridad los lineamientos para los principios de ingeniería de computación, de acuerdo a las políticas o estándares de seguridad institucional.
7.9.10 **Pruebas de seguridad.**	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área del INSTITUTO NICARAGUENSE DE ENERGIA (INE), se realizan pruebas de seguridad del sistema.
	Conclusión y recomendación

	Se recomienda definir dentro de la metodología de Desarrollo, en la fase de pruebas, una etapa para la realización de pruebas de seguridad y que deben competer al área de seguridad informática. El área de Seguridad en TI debe ser el responsable de la preparación y ejecución de las pruebas de red para obtener información.

7.9.11 Requisitos ISO 27001:2013

Nivel de riesgo expuesto.	
Alto	Este tipo de riesgos deben ser minimizados, aunque esto suponga una inversión económica, de tiempo, recursos institucionales, entre otros, siempre y cuando los recursos asignados no afecten la operativa o causen nuevos riesgos de otra índole. se requiere una evaluación constante de las medidas implementadas para ajustarlas según sea necesario y mantener la resiliencia ante posibles amenazas.

Porcentaje de cumplimiento.

Ilustración 19 Porcentaje de cumplimiento de Adquisición, Desarrollo y Mantenimiento de la red "autoría propia"

7.10 Cláusula Relaciones con Proveedores.

Definición según el dominio de la norma – Relaciones con Proveedores
Para garantizar que la protección de los activos de la organización sea accesible por los proveedores.
Madurez Repetible.
Nivel de madurez general.

Ilustración 20 Relaciones con Proveedores "autoría propia"

Situación evidenciada.	
Hallazgos no satisfactorios.	
7.10.1 Clausula Seguridad en relaciones con el proveedor.	
7.10.2 Política de Seguridad de la Información para relaciones con proveedores.	**Hallazgos identificados.**
	De acuerdo con la entrevista realizada al área de informática del INSTITUTO NICARAGUENSE DE ENERGIA (INE), no se encuentran definidos los lineamientos para el trato con terceros para la confidencialidad de la información institucional formalmente.
	Conclusiones y recomendaciones.
	Se recomienda incluir dentro de la política de Seguridad los lineamientos para el tratamiento de la información corporativa con terceros. Se debe realizar un control sobre el registro de acceso y salida del personal tercerizado de la institución diariamente. Al término de la contratación solicitar al ente tercerizado la devolución de todo tipo de accesos, información al responsable del INSTITUTO NICARAGUENSE DE ENERGIA (INE). Asegurar el borrado de información segura de los equipos de terceros. Para evitar la fuga de información en el trato de terceros.
7.10.3 Atención de tópicos de seguridad dentro de los acuerdos con proveedores.	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área de informática del INSTITUTO NICARAGUENSE DE ENERGIA (INE), hay definidos lineamientos para el trato con terceros que detallen medidas o controles de seguridad necesarios.
	Conclusiones y recomendaciones.

	Se recomienda incluir dentro de la política de Seguridad los lineamientos para el tratamiento de la información corporativa con terceros. Se debe realizar un control sobre el registro de acceso y salida del personal tercerizado de la institución diariamente.
7.10.4 Gestión de entrega de servicios de proveedor.	

7.10.5 Monitoreo y revisión de servicios de proveedor.	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área de informática del INSTITUTO NICARAGUENSE DE ENERGIA (INE), se verifico que se realizan monitoreo de los servicios contratados a terceros para corroborar el cumplimiento del contrato, sin embargo, se tiene definida una periodicidad para realizar estos análisis.
	Conclusiones y recomendaciones.
	Se recomienda definir un proceso estandarizado para el proceso de monitoreo y revisión de servicios de proveedor o al menos un alcance definido a los proyectos de carácter crítico a todas las dependencias pertenecientes al INE.
7.10.6 Gestión de cambios a servicios de proveedor.	**Hallazgos identificados.**
	De acuerdo con la entrevista realizada al área de tecnología, no se tienen definidos controles para documentar cambios que puedan afectar la disponibilidad de la información del INSTITUTO NICARAGUENSE DE ENERGIA. Sin embargo, se realiza una revisión anual de los contratos.
	Conclusiones y recomendaciones.
	Se recomienda definir un proceso estandarizado para el proceso de monitoreo y revisión de servicios de proveedor o al menos un alcance definido a los proyectos de carácter crítico a todas las dependencias pertenecientes al INSTITUTO NICARAGUENSE DE ENERGIA.
Nivel de riesgo expuesto.	
Alto	Este tipo de riesgos deben ser minimizados, aunque esto suponga una inversión económica, de tiempo, recursos institucionales, entre otros, siempre y cuando los recursos asignados no afecten la operativa o causen nuevos riesgos de otra índole.
Porcentaje de cumplimiento.	

Ilustración 21 Porcentaje de cumplimiento de Relaciones con Proveedores "autoría propia"

7.11 Cláusula Gestión de Incidentes de Seguridad de la Información.

Definición según el dominio de la norma – Gestión de incidentes.

Para garantizar un enfoque coherente y eficaz para la gestión de seguridad de la información, incidentes, incluyendo la comunicación de eventos de seguridad y debilidades.

Ilustración 22 Gestión de Incidentes de Seguridad de la Información

Madurez Repetible	
Nivel de madurez general.	
Situación evidenciada.	
Hallazgos no satisfactorios.	
7.11.1 Gestión de incidentes de seguridad de la información y mejoras.	
	Hallazgos identificados.
	De acuerdo con la sesión obtenida con el área de Infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), actualmente hay definido un proceso formal para la gestión de incidentes de seguridad de la Información. El área de Seguridad maneja un flujo sobre la

7.11.2 Responsabilidades y procesos.	gestión de los incidentes, pero hay un procedimiento formal que defina la clasificación y el esquema de atención, responsabilidades y roles que deberían ejecutarse. Así mismo, dicho documento carece de firmas de aprobación, persona responsable de revisarlo, persona responsable de elaborarlo, controles de versión. indica el procedimiento que debe realizar el usuario final para notificar una incidencia.
	Conclusión y recomendación.
	Se recomienda definir un proceso formal para la gestión de incidentes y problemas de seguridad de la información. Para el diseño de un proceso de gestión de incidentes se puede tomar como referencia marco de trabajo de buenas prácticas como COBIT 5 o bien ITIL en la gestión de incidentes y problemas.
7.11.3 Reporte de eventos de	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el Área de Infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), a pesar de que el módulo de ayuda recibe el tiquete de solicitud de atención hay canal formalizado sobre la gestión de incidentes de seguridad de la información.
	Conclusión y recomendación.

Seguridad de la Información.	Se recomienda definir un proceso formal para la gestión de incidentes y problemas de seguridad de la información. Para el diseño de un proceso de gestión de incidentes se puede tomar como referencia marco de trabajo de buenas prácticas como COBIT 5 o bien ITIL en la gestión de incidentes y problemas.
	Hallazgos identificados.
7.11.4 Reporte de debilidades de seguridad	De acuerdo con la sesión obtenida con el área de Infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), a pesar de que el módulo de ayuda recibe el tiquete de solicitud de atención no hay un canal formalizado sobre la gestión de incidentes de seguridad de la información. Hay definidos tiempos de atención, tiempos de respuesta, hay definidos niveles de atención entre otros.
	Conclusión y recomendación.

de la información.	Se recomienda definir un proceso formal para la gestión de incidentes y problemas de seguridad de la información. Para el diseño de un proceso de gestión de incidentes se puede tomar como referencia marco de trabajo de buenas prácticas como COBIT 5 o bien ITIL en la gestión de incidentes y problemas.
7.11.5 Valoración y decisión de eventos de seguridad de la información.	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área de Infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), existen procedimientos para la clasificación y tratamiento de los incidentes. hay un registro de incidentes de seguridad de la información.
	Conclusión y recomendación.
	Se recomienda definir un proceso formal para la gestión de incidentes y problemas de seguridad de la información. Para el diseño de un proceso de gestión de incidentes se puede tomar como referencia marco de trabajo de buenas prácticas como COBIT 5 o bien ITIL en la gestión de incidentes y problemas.
7.11.6	**Hallazgos identificados.**

Aprendizaje de incidentes de seguridad de la información.	De acuerdo con la sesión obtenida con el área de Infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), existe la definición de una Base de datos de conocimiento de los incidentes de seguridad de la información.
	Conclusión y recomendación.
	Se recomienda definir un proceso formal para la gestión de incidentes y problemas de seguridad de la información. Para el diseño de un proceso de gestión de incidentes se puede tomar como referencia marco de trabajo de buenas prácticas como COBIT 5 o bien ITIL en la gestión de incidentes y problemas.
7.11.7 Recopilación de evidencia.	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área de Infraestructura del INSTITUTO NICARAGUENSE DE ENERGIA (INE), existe la definición de un procedimiento para la recolección de la evidencia de los incidentes detectados.
	Conclusión y recomendación.

	Se recomienda definir un proceso formal para la gestión de incidentes y problemas de seguridad de la información. Para el diseño de un proceso de gestión de incidentes se puede tomar como referencia marco de trabajo de buenas prácticas como COBIT 5 o bien ITIL en la gestión de incidentes y problemas.	
Nivel de riesgo expuesto.		
	Alto	Este tipo de riesgos deben ser minimizados, aunque estosuponga una inversión económica, de tiempo, recursos institucionales, entre otros, siempre y cuando los recursos asignados afecten la operativa o causen nuevos riesgos de otra índole.
Porcentaje de cumplimiento.		

Ilustración 23 Gestión de Incidentes de Seguridad de la Información

7.12 spectos de Seguridad de la Información para la Gestión de Continuidad del Negocio

Definición según el dominio de la norma – Aspectos de Seguridad de la Información para la Gestión de Continuidad de la institución.

La seguridad de la información debe estar implícita en la organización en este caso el INSTITUTO NICARAGUENSE DE ENERGIA (INE), y en su gestión de la continuidad de la empresa.

Madurez Definido.

Nivel de madurez general.

Ilustración 24 Aspectos de Seguridad de la Información para la Gestión de Continuidad del Negocio "autoría propia"

Situación evidenciada.	
7.12.1 Requisitos ISO 27001:2013.	
7.12.2 Redundancias.	
7.12.3 Disponibilidad de facilidades de	**Hallazgos identificados**
	De acuerdo con la sesión realizada con el área de informática del INSTITUTO NICARAGUENSE DE ENERGIA (INE), verificamos que se maneja una redundancia de datos para lograr la mayor disponibilidad de la información, esto se logra mediante una configuración Activo-Activo de los dos centros

procesamiento de información	de datos (Primario y Secundario), sin embargo, como el proyecto es nuevo se ha definido documentación al respecto donde se detallen estas configuraciones.
	Conclusión y recomendación
	Se recomienda la elaboración de los procedimientos que garanticen la adecuada configuración en los equipos de telecomunicaciones en el INSTITUTO NICARAGUESE DE ENERGIA (INE), para proveer la suficiente disponibilidad de los requerimientos de procesamiento de información.
Nivel de riesgo expuesto	
Alto	Este tipo de riesgos deben ser minimizados, aunque esto suponga una inversión económica, de tiempo, recursos institucionales, entre otros,

Ilustración 25 Porcentaje de cumplimiento de Aspectos de Seguridad de la Información para la Gestión de Continuidad del Negocio "autoría propia"

7.13 Cláusula Cumplimiento.
Definición según el dominio de la norma – Cumplimiento.
Para evitar incumplimientos de las obligaciones legales, estatutarias, reglamentarias o contractuales en materia de información de seguridad y de los requisitos de seguridad.
Madurez Repetible.
Nivel de madurez general.
 Ilustración 26 Cumplimiento "autoría propia"
Situación evidenciada.
Hallazgos no satisfactorios.
7.13.1 Cumplimientos de los requisitos legales y contractuales.

	Hallazgos identificados.

7.13.2 **Identificación de la legislación aplicable y los requisitos contractuales.**	EL INSTITUTO NICARAGUESE DE ENERGIA (INE), es una institución de carácter público y se encuentra bajo la regulación de la Contraloría General de la República. De igual manera se realiza de manera anual una auditoria basada en las normas gubernamentales de Nicaragua (NAGUN). Sin embargo, no se encuentran documentados todos los requerimientos de los estatutos regulatorios que el INSTITUTO NICARAGUESE DE ENERGIA (INE), debe cumplir para toda su información.
	Conclusión y recomendación.

	Se recomienda definir un proceso formal que defina los lineamientos para los Derechos de Propiedad Intelectual en donde se asegure el cumplimiento legal, regulatorio y contractual de los requerimientos de Derechos de Propiedad Intelectual, uso de productos de software. Es necesario además definir los lineamientos para el cumplimiento de los derechos de propiedad intelectual que define el uso legal de software y productos de información.
7.13.3 Derechos de propiedad intelectual (IPR).	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área de Informática del INSTITUTO NICARAGUENSE DE ENERGIA (INE), se identificó que no se tiene documentado un procedimiento donde se asegure el cumplimiento legal y regulatorio sobre los derechos de propiedad intelectual y uso de productos de software. Actualmente se maneja software ofimático licenciado en las máquinas de colaboradores.
	Conclusión y recomendación.
	Se recomienda definir un proceso formal que defina los lineamientos para los Derechos de Propiedad Intelectual en donde se asegure el cumplimiento legal, regulatorio y contractual de los requerimientos de Derechos de Propiedad Intelectual, uso de productos de software. Es necesario además definir los lineamientos para el cumplimiento de los derechos de propiedad intelectual que define el uso legal de software y productos de información. Entre otros lineamientos necesarios se recomienda definir: • Los lineamientos para los contratos con los distribuidores de software para identificar la legalidad y el complimiento de los derechos de autor.

	La definición de los controles y registros de activos que logren identificar los activos con requisitos de protección de derechos de propiedad intelectual. • Definición de lineamientos para el resguardo apropiado de las condiciones de las licencias adquiridas. • Definición de lineamientos para la transferencia y eliminación de software.
7.13.4	**Hallazgos identificados.**

Protección de los registros.	De acuerdo con la sesión realizada con el área de Informática del INSTITUTO NICARAGUENSE DE ENERGIA (INE), verificamos que la información es almacenada de manera histórica, y se tienen definidos procedimientos que aseguren la protección de dicha información, así como los tiempos que deben permanecer almacenada.
	Conclusión y recomendación.
	Se recomienda definir un proceso formal que defina los lineamientos para los Derechos de Propiedad Intelectual en donde se asegure el cumplimiento legal, regulatorio y contractual de los requerimientos de Derechos de Propiedad Intelectual, uso de productos de software. Es necesario además definir los lineamientos para el cumplimiento de los derechos de propiedad intelectual que define el uso legal de software y productos de información. Entre otros lineamientos necesarios se recomienda definir: • Los lineamientos para los contratos con los distribuidores de software para identificar la legalidad y el complimiento de los derechos de autor. • La definición de los controles y registros de activos que logren identificar los activos con requisitos de protección de derechos de propiedad intelectual. • Definición de lineamientos para el resguardo apropiado de las condiciones de las licencias adquiridas. • Definición de lineamientos para la transferencia y eliminación de software.

7.13.5 Protección de datos y privacidad de la	**Hallazgos identificados.**
	De acuerdo a la reunión realizada con el área de tecnología del INSTITUTO NICARAGUENSE DE ENERGIA (INE), verificamos que se aplica controles

información personal.	para la protección de la información y la divulgación ni la exposición de datos sin consentimiento.
	Conclusión y recomendación.

	Se recomienda aplicar controles más robustos para la protección de datos y privacidad de la información personal. En este punto es recomendable de acuerdo con el procedimiento de clasificación y etiquetado de la información, que información es de carácter personal y la cuál debe ser custodiada con todas las medidas de seguridad del INE.
7.13.6 Regulación de controles criptográficos.	**Hallazgos identificados.**
	De acuerdo con la sesión obtenida con el área de informática del INSTITUTO NICARAGUENSE DE ENERGIA (INE), actualmente se tiene normado, existe un proceso de gestión sobre la aplicación y regulación de controles criptográficos.
	Conclusión y recomendación.
	Se recomienda definir un proceso formal que gestione el uso de controles criptográficos para la protección de la información. Una vez definido dicho proceso se debe por medio de la normativa interna definir los lineamientos necesarios sobre las regulaciones para la gestión de los controles criptográficos.
7.13.7 Revisiones de seguridad de la información.	
7.13.8 Revisión independiente de la seguridad de la información.	**Hallazgos identificados.**
	De acuerdo con la información obtenida y sesiones efectuadas en el INSTITUTO NICARAGUENSE DE ENERGIA (INE), durante las diferentes entrevistas, el área de seguridad informática carece de la definición de procesos formales.
	Conclusión y recomendación.
	Es indispensable que el área de Seguridad defina la estructura de procesos. Dentro de esos procesos se debe definir un proceso de revisión y monitoreo sobre el desempeño de la seguridad de TI que al menos se efectué entre 1 y 2 veces al año.
	Hallazgos identificados.

7.13.9 **Cumplimiento de las políticas y Normas de Seguridad.**	De acuerdo a la sesión obtenida con el área de informática del INSTITUTO NICARAGUENSE DE ENERGIA (INE), se identificó que se realizan revisiones sobre el cumplimiento de la normativa de la contraloría general de la república. Solamente auditoría interna realiza estas revisiones.
	Conclusión y recomendación.
	Se recomienda definir un proceso que compruebe periódicamente el cumplimiento de los procedimientos, políticas, normas, manuales definidos por el Subárea de seguridad entre otros, dentro de su área de responsabilidad. Esto debe aplicarse como un proceso de control operativo del Área de Seguridad.
Nivel de riesgo expuesto.	
Alto	Este tipo de riesgos deben ser minimizados, aunque esto suponga una inversión económica, de tiempo, recursos institucionales, entre otros, siempre y cuando los recursos asignados afecten la operativa o causen nuevos riesgos de otra índole.
Porcentaje de cumplimiento.	

Ilustración 27 Porcentaje de cumplimiento Final "autoría propia"

8. Diagnóstico de la situación actual y análisis del nivel de madurez del SGSI.

La información en todas sus formas (impresa o digital) es uno de los principales activos de cualquier organización en este caso en particular es el INSTITUTO NICARAGUENSE DE ENERGIA INE ya que son el medio por el cual las empresas e instituciones pueden lograr la consecución de los objetivos de acuerdo a la forma en que utilizan la información. Por lo cual, se debe garantizar su confidencialidad, integridad y disponibilidad.

En este apartado se desarrollará un diagnóstico de la situación actual para cada uno de los requerimientos establecidos en el ISO 27001:2013 cláusulas y los controles de seguridad establecidos de esta norma.

Para cada uno de los requerimientos establecidos en el ISO 27001:2013 y controles considerados en el anexo A, se analiza la gestión desarrollada por el INSTITUTO NICARAGUENSE DE ENERGIA (INE) en pro de alinearse al cumplimiento de las mejores prácticas, lo cual permite ubicar esta gestión actual en una escala de madurez.

Para por cada una de las cláusulas del ISO 27001 y los controles se presenta el análisis del nivel de madurez del SGSI y el cumplimiento de los controles.

Por lo cual, en los apartados de este documento, se podrán observar las brechas que deben subsanarse para asegurar la confidencialidad, integridad, disponibilidad y no repudio de la información.

A continuación, se muestran los gráficos que resumen el nivel de madurez actual sobre las condiciones del SGSI del INSTITUTO NICARAGUENSE DE ENERGIA (INE) y las oportunidades de mejora acorde con el diagnóstico efectuado con la norma ISO/IEC 27001- 27002:2013.

8.1 Resultados del estado de implementación del SGSI.				
1.Resultados del ISO/IEC 27001:2013 por dominio.	Puntuación máxima.	Puntuación actual.	Porcentaje.	Nivel de madurez.
4 Contexto de la organización.	70	14	20%	1 inicial/Ad Hoc
5 Liderazgo.	170	44	26%	1 inicial/Ad Hoc
6 Planeación.	200	42	21%	1 inicial/Ad Hoc
7 Soporte.	90	20	22%	1 inicial/Ad Hoc
8 Operaciones .	70	14	20%	1 inicial/Ad Hoc
9 Evaluación del desempeño.	30	6	20%	1 inicial/Ad Hoc
10 Mejoras.	20	4	20%	1 inicial/Ad Hoc
A.5 Política de seguridad.	20	6	30%	1 inicial/Ad Hoc
A.6 Instituto Nicaragüense de Energía la seguridad de la información.	70	6	9%	1 inicial/Ad Hoc
A.7 Seguridad de recursos humanos	60	7	11%	1 inicial/Ad Hoc
A.8 Gestión de activos	90	17	19%	1 inicial/Ad Hoc
A.9 Control de acceso	130	21	16%	1 inicial/Ad Hoc
A.10 Criptografía	20	0	0%	1 inicial/Ad Hoc
A.11 Seguridad física y de entorno.	150	12	8%	1 inicial/Ad Hoc

A.12 Seguridad en las operaciones.	140	34	24%	1 inicial/Ad Hoc
A.13 Seguridad en las comunicaciones.	70	34	49%	2 repetible pero intuitivo
A.14 Adquisición, desarrollo y mantenimiento.	130	13	10%	0 inexistente
A.15 Relaciones con proveedores.	50	13	26%	0 inexistente
A.16 Gestión de incidentes de la seguridad de la información.	70	4	6%	0 inexistente
A.17 Aspecto de la seguridad de la información para la gestión y continuidad del negocio u organismo.	40	9	22%	0 inexistente
A.18 Cumplimiento.	60	13	22%	1 inicial/Ad Hoc

Tabla No 2 Resumen de resultados por dominio

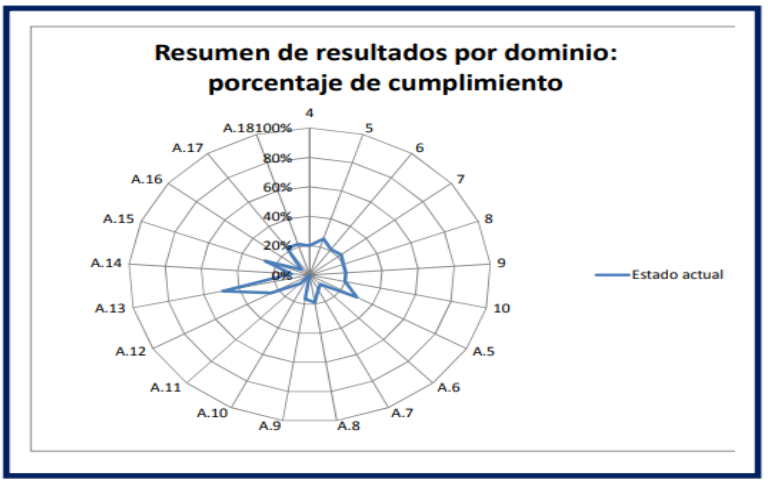

Ilustración 28 Porcentaje de Cumplimiento. "Autoría propia"

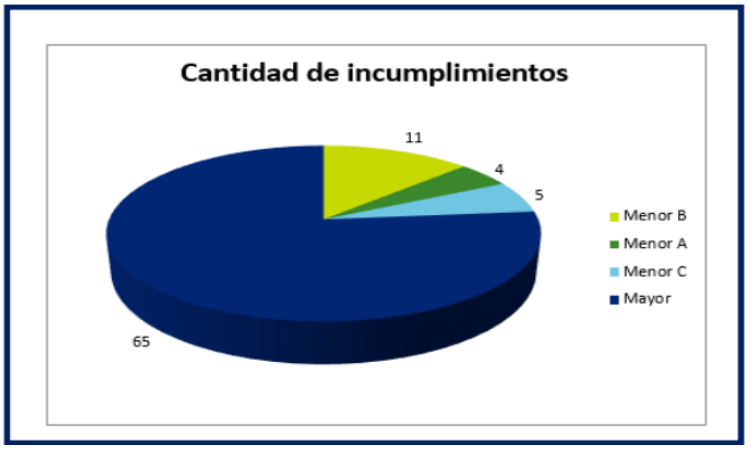

Ilustración 29 Cantidad de incumplimientos a los controles. "Autoría propia"

9. Proceso de elaboración del PGSI.

9.1 Análisis Estratégico.

La evaluación de las iniciativas se llevará a cabo en base a dos criterios fundamentales: el valor generado y la complejidad de implementación. A continuación, se detalla el proceso para evaluar cada uno de estos criterios:

9.1.1 Valor generado.

Para evaluar el valor generado por cada iniciativa, se considerará el resultado del diagnóstico del contexto y situación actual. Este diagnóstico ha permitido identificar diversos aspectos críticos, como riesgos, amenazas y vulnerabilidades que afectan la integridad de la información, la protección de los activos y la infraestructura de información del Instituto Nicaragüense de Energía. Los componentes clave que se evaluarán son:

1. **Riesgos**: Factores o eventos que pueden tener un impacto negativo en los objetivos del Instituto.
2. **Amenazas**: Elementos externos o internos que podrían explotar vulnerabilidades y causar daños.
3. **Vulnerabilidades**: Debilidades o fallos en los sistemas, procesos o controles que pueden ser explotados por amenazas.
4. **Oportunidades de mejora**: Identificación de áreas donde se pueden implementar mejoras para mitigar riesgos y fortalecer la protección de los activos y la infraestructura de información.

En la Tabla No. 2 se presenta una síntesis de los criterios de riesgos, amenazas y vulnerabilidades, así como las oportunidades de mejora generales en el Instituto Nicaragüense de Energía. Estos aspectos se evaluarán para determinar el valor potencial que cada iniciativa puede generar si se implementa adecuadamente.

9.2 Diseño de Estrategias.

9.2.1 Identificación de Estrategias

Como resultado de la fase de diagnóstico del contexto y situación actual, se identificaron diversas brechas en la integridad de la información, la protección de activos y la infraestructura de información. Para abordar estas brechas, se han diseñado estrategias específicas, cada una de las cuales tiene un identificador único que facilita su seguimiento y gestión.

9.2.1.1 Estructura del Identificador de Estrategias

Cada estrategia se identifica mediante un código compuesto por la palabra "INI" seguida de un número secuencial. Esta estructura permite una referencia clara y sistemática a cada estrategia. Por ejemplo:

- ✓ INI-001
- ✓ INI-002
- ✓ INI-003

9.2.2 Datos Compuestos en la Identificación de Estrategias

9.2.2.1 Figura No. 2: Componentes de Identificación de Estrategias.

Identificador	Descripción	Objetivo	Responsable	Plazo	Indicadores de Éxito
INI-001	Implementación de un Sistema de Gestión de Seguridad de la Información (SGSI).	Proteger la información crítica del Instituto.	Departamento de TI.	6 meses.	Reducción del 50% en incidentes de seguridad.
INI-002	Capacitación en Seguridad de la Información para el Personal.	Aumentar la conciencia y conocimientos sobre seguridad de la información.	Recursos Humanos.	3 meses.	80% de participación y calificación superior al 85% en pruebas.
INI-003	Actualización de la Infraestructura de Red.	Mejorar la resistencia y rendimiento de la red del Instituto.	Departamento de TI.	9 meses.	Incremento del 30% en la velocidad de red y reducción de 40% en tiempos de inactividad.
INI-004	Auditorías de Seguridad de la Información.	Evaluar y mejorar continuamente la seguridad de la información.	Auditoría Interna.	Cada 6 meses.	Informe de auditoría con recomendaciones y plan de acción implementado en un 90%.

	INI-005	Implementación de un Sistema de Respaldo y Recuperación de Datos.	Garantizar la disponibilidad y recuperación de información en caso de incidentes.	Departamento de TI.	4 meses.	Respaldo completo semanal y recuperación exitosa en simulacros trimestrales.

9.2.3 Descripción Detallada de las Estrategias

9.2.3.1 INI-001: Implementación de un Sistema de Gestión de Seguridad de la Información (SGSI)

Descripción: Desarrollo e implementación de un SGSI basado en estándares internacionales (por ejemplo, ISO/IEC 27001) para proteger la información crítica del Instituto.
Objetivo: Garantizar la confidencialidad, integridad y disponibilidad de la información.
Responsable: Departamento de TI.
Plazo: 6 meses.
Indicadores de Éxito: Reducción del 50% en incidentes de seguridad documentados.

9.2.3.2 INI-002: Capacitación en Seguridad de la Información para el Personal

Descripción: Programa de formación continua en seguridad de la información para todos los empleados del Instituto.
Objetivo: Aumentar la conciencia y conocimientos sobre prácticas seguras de manejo de información.
Responsable: Recursos Humanos.
Plazo: 3 meses.
Indicadores de Éxito: 80% de participación y calificación superior al 85% en pruebas de conocimiento.

9.2.3.3 INI-003: Actualización de la Infraestructura de Red

Descripción: Modernización de los equipos y protocolos de la red para mejorar su rendimiento y seguridad.
Objetivo: Mejorar la resistencia y rendimiento de la red del Instituto.
Responsable: Departamento de TI.
Plazo: 9 meses.
Indicadores de Éxito: Incremento del 30% en la velocidad de red y reducción de 40% en tiempos de inactividad.

9.2.3.4 INI-004: Auditorías de Seguridad de la Información

Descripción: Realización de auditorías periódicas para evaluar la efectividad de las medidas de seguridad implementadas.
Objetivo: Evaluar y mejorar continuamente la seguridad de la información.
Responsable: Auditoría Interna.
Plazo: Cada 6 meses.
Indicadores de Éxito: Informe de auditoría con recomendaciones y plan de acción implementado en un 90%.

9.2.3.5 INI-005: Implementación de un Sistema de Respaldo y Recuperación de Datos

Descripción: Establecimiento de procedimientos y sistemas para la copia de seguridad y recuperación de datos.
Objetivo: Garantizar la disponibilidad y recuperación de información en caso de incidentes.
Responsable: Departamento de TI.
Plazo: 4 meses.
Indicadores de Éxito: Respaldo completo semanal y recuperación exitosa en simulacros trimestrales.

9.3 Plan de acción.

Este plan de acción se desarrolló en un plazo de 1 año y documenta los objetivos, recursos, roles y responsabilidades requeridos para ejecutar las iniciativas identificadas.

Nombre	Objetivo	Usuario	Tecnológico
INI 01 - Políticas de Seguridad de la Información.	INI 01 - Políticas de Seguridad de la Información del INE.	1 - Administrador de iniciativa. 1 - Director de iniciativa. 1 - Profesional seguridad de la información.	Microsoft Office.
INI 02 - Seguridad en la gestión de recursos humanos.	Asegurar que los empleados y contratistas sean conscientes de y cumplan con las responsabilidades de seguridad de la información.	1 - Administrador de iniciativa 1 - Director de iniciativa. 1 - Profesional seguridad de la información.	Microsoft Office.

INI 03 - Gestión de activos.	Identificar los activos del INE, clasificarlos e identificar los riesgos a los que están expuestos.	1 - Administrador de iniciativa. 1 - Profesional seguridad operativa. 1 - Profesional seguridad de la Información.	Herramienta para la clasificación de datos.

INI 04 - Gestión de acceso – Depuración de usuarios.	Valorar y ajustar los privilegios asignados a los usuarios con base a las necesidades del negocio.	1 - Administrador de iniciativa. 1 - Profesional seguridad de la información. 1 – Evaluador. 1 - Encargado del área.	Herramientas para la evaluación de privilegios.
INI 06 - Gestión de acceso – Administración de identidades y acceso.	Valorar y ajustar los privilegios asignados a los usuarios con base a las necesidades del negocio.	1 - Administrador de iniciativa 1 - Profesional seguridad de la información. 1 - Profesional seguridad operativa.	Herramientas en el mercado para la gestión de identidades y accesos (ejemplo Oracle Identity and Access Management Suite Plus).
INI 07 - Gestión de vulnerabilidades y parches.	Reducir los riesgos resultantes de la explotación de vulnerabilidad en técnicas publicadas.	1 - Administrador de iniciativa. 1 - Profesional seguridad de la información. 1 - Experto en gestión de vulnerabilidades.	Herramientas para la gestión de vulnerabilidades McAfee Vulnerability.
INI 08 - Control de acceso a red.	Monitorear en tiempo real los dispositivos conectados a la red de.	1 - Administrador de iniciativa. 1 - Profesional seguridad de la información. 1 - Profesional seguridad operativa.	Herramienta de la solución NAC, basada en la solución CISCO NAC Appliance 3350 Srv Max 1500u.

INI 09 - Gestionar dispositivos móviles.	Garantizar que el uso de dispositivos móviles en el INE sea seguro	1 - Administrador de iniciativa. 1 - Profesional en Seguridad de la Información. 1 - Profesional seguridad operativa informática	Solución MDM basados en la solución de IBM, Endpoint Manager for Mobile Devices Client Device License.

INI 10 - Capacitación y concienciación.	Implementar el programa de seguridad de la información.	1 - Profesional en Seguridad de la Información.	Correo electrónico. Portal Web. Ventanas emergentes.
INI 11 – Respaldos.	Realizar respaldos a la información de forma periódica con base al nivel de clasificación.	1 - Administrador de iniciativa. 1 - Director de iniciativa. 1 - Profesional seguridad operativa Informática.	Herramienta para ejecutar respaldos en línea.
INI 12 - Implementar Centro de Operaciones de Seguridad	Establecer un centro de operaciones de seguridad encargado de detectar, identificar y atender los incidentes de seguridad de Información.	1 - Administrador de iniciativa. 1 - Profesional de seguridad de la información.	Depende del plan de implementación a documentar.
INI 13 – Herramienta de seguridad de la información	Automatizar la gestión de seguridad de la información.	1 - Director de la iniciativa. 1 - Profesional seguridad de la información.	Herramienta para la gestión de seguridad de la información.

INI 14 - Piloto ejecución evaluación interna	Ejecutar autoevaluaciones de seguridad para identificar deficiencias en el sistema de gestión y ejecutar planes de acción para la mejora.	1 - Administrador de iniciativa.	PPM. (Policy and Procedure Manager).

10. Estrategias.

Es importante destacar que la ciberseguridad es un tema relevante en la actualidad, y el Instituto Nicaragüense de Energía INE están implementando estrategias para proteger sus informaciones de posibles amenazas cibernéticas. Si el INE está interesado en desarrollar una estrategia de ciberseguridad, podría considerar los siguientes pasos:

- ✓ **Implementar un modelo de seguridad en capas**: Esto implica utilizar controles de seguridad en diferentes niveles, como controles de red, punto final, borde, aplicación y centro de datos. Un enfoque en capas ayuda a dificultar el acceso no autorizado a los archivos y datos del INE.
- ✓ **Educación en seguridad cibernética**: La educación y concientización de los empleados sobre las prácticas de higiene cibernética y cómo detectar un ataque de ransomware son una gran defensa contra los atacantes inteligentes. Enseñar a los empleados a reconocer correos electrónicos sospechosos, enlaces maliciosos y archivos adjuntos peligrosos puede ayudar a prevenir infecciones por ransomware.
- ✓ **Mantener sistemas actualizados**: Mantener los sistemas operativos y el software actualizados con los últimos parches de seguridad es esencial para protegerse contra las vulnerabilidades conocidas que los atacantes pueden aprovechar. Esto reduce las posibilidades de que los infractores exploren vulnerabilidades ya resueltas.
- ✓ **Realizar copias de seguridad regulares**: Realizar copias de seguridad periódicas de los datos importantes y almacenarlas en un lugar seguro fuera de la red puede ayudar a recuperarse de un ataque de ransomware sin tener que pagar un rescate. Las copias de seguridad deben ser probadas y verificadas regularmente para garantizar su integridad y disponibilidad.
- ✓ **Utilizar soluciones de seguridad confiables**: Implementar soluciones de seguridad, como analizadores de virus y filtros de contenido en los servidores de correo electrónico, puede ayudar a prevenir la entrada de ransomware en los sistemas. Además, es importante utilizar software de seguridad confiable y mantenerlo actualizado para protegerse contra las últimas amenazas de ransomware.

11. Resumen Ejecutivo.

En esta sección se brinda un resumen a nivel general de los resultados del análisis de vulnerabilidades efectuado a la plataforma tecnológica, el cual se divide en dos partes exposición de riesgos de la plataforma y resumen de las vulnerabilidades presentadas.

11.1 Exposición al riesgo de la plataforma

A continuación, se brinda un resumen general de la exposición al riesgo tecnológico al cual está expuesto el segmento de red analizado.

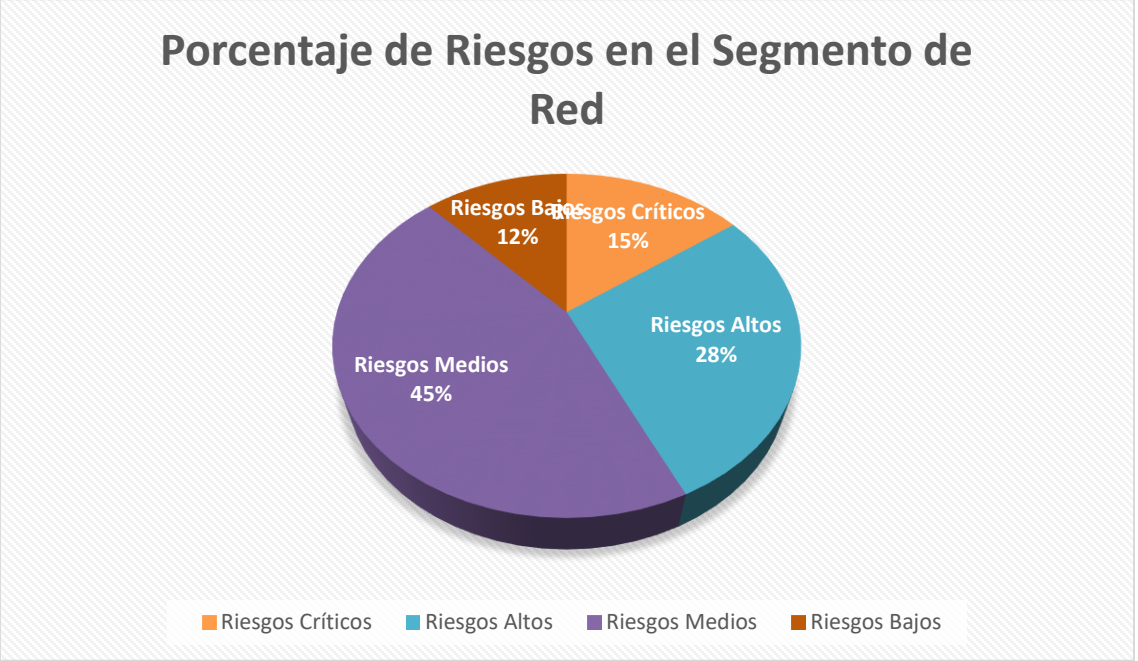

Ilustración 30 Porcentaje de Riesgos en el Segmento de Red "autoría propia"

A continuación, se brinda un resumen general de la exposición al riesgo tecnológico al cual está expuesto el segmento de red analizado.

Como se puede observar en la ilustración se utiliza un análisis cualitativo de los riesgos (mayor detalle en la sección técnica), donde el riesgo crítico pone en peligro el servicio, la plataforma y/o información y cuentan con alta probabilidad de éxito, mientras que los riesgos catalogados como “bajos” presentan la menor combinación impacto x probabilidad.

En el caso de este segmento de red se lograron identificar 77 vulnerabilidades, de las cuales 54 (15%) corresponden a vulnerabilidades críticas, pueden causar interrupción del servicio en caso de ser explotadas, mientras que existen 159 (45%) que pueden ser utilizadas para comprometer los equipos o sus capacidades de seguridad para así obtener información del Instituto Nicaragüense de Energía.

12. Detalle Técnico de Vulnerabilidades y Análisis.

Se proporciona un resumen de los resultados del análisis de vulnerabilidades, detallando la clasificación de riesgos cualitativos:

- **Riesgos Críticos**: Vulnerabilidades con una nota máxima de 10 en la escala CVSS.
- **Riesgos Altos**: Vulnerabilidades que pueden comprometer la confidencialidad, integridad y disponibilidad de dispositivos críticos.
- **Riesgos Medios**: Vulnerabilidades que pueden comprometer algún atributo de seguridad.
- **Riesgos Bajos**: Vulnerabilidades menores, como la revelación de información no sensible.

Complejidad del ataque:

- **Alta**: Alta probabilidad de ataque, información de dominio público disponible, requiere recursos complejos

- **Media**: Probabilidad media de ataque, requiere recursos relativamente sencillos.
- **Baja**: Baja probabilidad de ataque, no requiere recursos complejos.

Equipos Afectados por Nivel de Riesgo

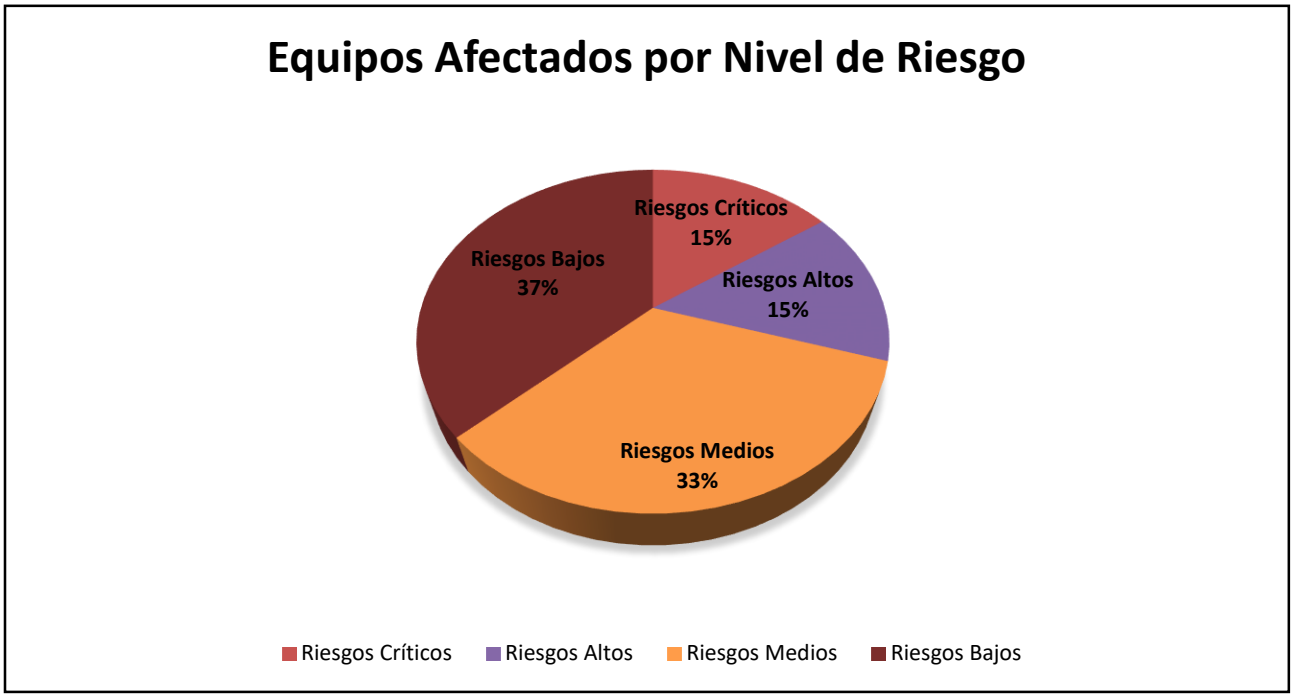

Ilustración 31 Equipos Afectados por Nivel de Riesgo "autoría propia"

cómo se puede observar en el Gráfico 30, las vulnerabilidades críticas afectan a menos de 10 equipos de los 27 evaluados, mientras que las vulnerabilidades categorizadas como bajas afectan 74% de los equipos.

13. Cronograma de Actividades.

Cronograma de Proyecto	**Meses**
Inicio	1
Capacitación al personal INE ISO 27001	1
Definición del líder de proyecto	1
Asignación del equipo de proyecto	1
Asignación de las responsabilidades del equipo de proyecto	1
Equipo de proyecto	2
Planificación	2
Documentación del plan de proyecto	2
Creación de la matriz de diagnóstico ISO27001	2
Definición de los requerimientos de documentación	2
Definición del equipo de trabajo	2
Reunión de inicio con el equipo de trabajo	2
Envío de los requerimientos de documentación	2
Revisión de Plan de proyecto	2
Ajustes de Plan de Proyecto por consultores MDCP	2
Entrega de Plan de Proyecto	3
Listado de documentos para verificar el cumplimiento	3
Matriz de diagnóstico ISO27001	3
Ejecución	3
Revisión de la documentación de diagnóstico	3
Diagnóstico del Sistema de Gestión	3
Clausula CONTEXTO	3
Entrevistas con el personal responsable	3
Evaluación de la documentación	3
Análisis de los criterios de evaluación	3
Análisis de brechas de cumplimiento	3
Documentación de observaciones y conclusiones	3
Clausula LIDERAZGO	3
Entrevistas con el personal responsable	3
Evaluación de la documentación	3
Análisis de los criterios de evaluación	3
Análisis de brechas de cumplimiento	3
Documentación de observaciones y conclusiones	3

Clausula PLANEACIÓN	3
Entrevistas con el personal responsable	3
Evaluación de la documentación	3
Análisis de los criterios de evaluación	3

Cronograma de Proyecto	**Meses**
Análisis de brechas de cumplimiento	3
Documentación de observaciones y conclusiones	3
Clausula SOPORTE	3
Entrevistas con el personal responsable	3
Evaluación de la documentación	3
Análisis de los criterios de evaluación	3
Análisis de brechas de cumplimiento	3
Documentación de observaciones y conclusiones	3
Clausula OPERACIÓN	6
Entrevistas con el personal responsable	6
Evaluación de la documentación	6
Análisis de los criterios de evaluación	6
Análisis de brechas de cumplimiento	6
Documentación de observaciones y conclusiones	6
Clausula EVALUACIÓN DE DESEMPEÑO	6
Entrevistas con el personal responsable	6
Evaluación de la documentación	6
Análisis de los criterios de evaluación	6
Análisis de brechas de cumplimiento	6
Documentación de observaciones y conclusiones	6
Clausula MEJORA	6
Entrevistas con el personal responsable	6
Evaluación de la documentación	6
Análisis de los criterios de evaluación	6
Análisis de brechas de cumplimiento	6
Documentación de observaciones y conclusiones	6
Ejecución del diagnóstico ISO27001	6
Clausula POLÍTICAS DE SEGURIDAD	6
Entrevistas con el personal responsable	6
Evaluación de la documentación	6
Análisis de los criterios de evaluación	6
Análisis de brechas de cumplimiento	6
Documentación de observaciones y conclusiones	6

Clausula 9. CONTROL DE ACCESOS	6
Entrevistas con el personal responsable	6
Evaluación de la documentación	6
Análisis de los criterios de evaluación	8
Análisis de brechas de cumplimiento	8

Cronograma de Proyecto	**Meses**
Documentación de observaciones y conclusiones	8
Clausula SEGURIDAD FÍSICA Y DEL AMBIENTE	8
Entrevistas con el personal responsable	8
Evaluación de la documentación	8
Análisis de los criterios de evaluación	8
Análisis de brechas de cumplimiento	8
Documentación de observaciones y conclusiones	8
Clausula GESTIÓN DE COMUNICACIONES Y OPERACIONES	8
Entrevistas con el personal responsable	8
Evaluación de la documentación	8
Análisis de los criterios de evaluación	8
Análisis de brechas de cumplimiento	8
Documentación de observaciones y conclusiones	8
Clausula TELECOMUNICACIONES	8
Entrevistas con el personal responsable	8
Evaluación de la documentación	8
Análisis de los criterios de evaluación	8
Análisis de brechas de cumplimiento	8
Documentación de observaciones y conclusiones	8
Clausula ADMINISTRACIÓN DE INCIDENTES	8
Entrevistas con el personal responsable	8
Evaluación de la documentación	8
Análisis de los criterios de evaluación	8
Análisis de brechas de cumplimiento	8
Documentación de observaciones y conclusiones	12
Clausula SEGURIDAD	12
Entrevistas con el personal responsable	12
Evaluación de la documentación	12
Análisis de los criterios de evaluación	12
Análisis de brechas de cumplimiento	12
Documentación de observaciones y conclusiones	12
Clausula SEGURIDAD DE LOS RRHH	12
Entrevistas con el personal responsable	12

Evaluación de la documentación	12
Análisis de los criterios de evaluación	12
Clausula ADMINISTRACIÓN DE ACTIVOS	12
Entrevistas con el personal responsable	12
Evaluación de la documentación	12

14. Análisis de costo.

14.1 Costos de Auditoría Basada en ISO27001.

- **Recurso Humano**: Auditor certificado en ISO27001.
- **Horario**: lunes a viernes, 8 horas diarias.

# Personas	Cargo	Total Meses	Pago Mensual ($)	Total ($)
1	Gerente	10	1,500.00	15,000.00

Pago total: $15,000.00

Adquisición de Software

Cantidad	Nombre del Programa	Precio ($)	Cantidad
1	Microsoft Project Pro 2019	1,000.00	1
1	Microsoft Office Pro 2019	700.00	1

Total: $1,700.00

Adquisición de Hardware

Cantidad	Descripción	Precio Unitario ($)	Total ($)
1	Computadora de Escritorio	550.00	550.00
1	Mesa de Computadora	100.00	100.00
1	Batería / Estabilizador	65.00	65.00

Total: $715.00

Costo Total: $17,415.00

15. CONCLUSIONES.

La auditoría de la red informática en el Instituto Nicaragüense de Energía (INE) conforme a la norma ISO/IEC 27001:2013, se finalizó cumpliendo con todos los objetivos establecidos en la presente tesis. El propósito principal de esta auditoría, como se definió en el objetivo general, era identificar posibles riesgos y vulnerabilidades en la infraestructura de la red del INE. A la vez que se cumplieron con éxito los objetivos específicos propuestos en la tesis. Al aplicar las normas establecidas en la ISO/IEC27001:2013 se han identificado los puntos débiles y se han destacado las áreas que requieren atención y mejora.

Además, se ha elaborado un Plan de Gestión de Seguridad de la Información (PGSI) destinado a cerrar las brechas identificadas en la red, de acuerdo con los estándares internacionales establecidos por ISO/IEC 27001:2013.

La evaluación de las vulnerabilidades ha permitido al INE fortalecer la postura de seguridad de la red informática y a mejorar su capacidad de respuesta ante amenazas cibernéticas.

En resumen, las buenas prácticas en el hacking ético en el Instituto Nicaragüense de Energía son en obtener el consentimiento, establecer un alcance claro, utilizar herramientas y técnicas adecuadas, documentar y reportar hallazgos, mantener la confidencialidad y actualizarse constantemente. Estas prácticas garantizan que las pruebas de penetración se realicen de manera ética y contribuyan a fortalecer la seguridad de red en dicha institución.

Finalmente, el trabajo monográfico detalló los resultados de la auditoría y proporcionó recomendaciones para fortalecer la seguridad de la información y proteger los activos del INE. En conjunto, esto demuestra el compromiso del INE con la seguridad cibernética y su adaptabilidad en un entorno digital en constante cambio.

16. RECOMENDACIONES:

En primer lugar, se recomienda con especial atención la renovación del firewall o que el existente este actualizado con su firmware más reciente para detectar cualquier ataque malicioso, la detección de intrusiones, la prevención de malware y el control de acceso contra la red y que permita una mayor visibilidad sobre la infraestructura de red.

Es importante considerar la concientización y capacitación en ciberseguridad para todos los empleados del INE. La educación sobre las amenazas cibernéticas y las mejores prácticas de seguridad informática es esencial para crear una cultura de seguridad en toda la organización y reducir la probabilidad de incidentes causados por errores humanos o comportamientos de riesgo.

Realizar un cambio de la topología de red de cableado categoría 5 hacia categoría par trenzado CAT7A.

Además, recomendamos adquirir un Sistemas de detección y prevención de intrusiones (IDS/IPS), como Cisco Firepower Nex-Generation IPS: que usa detección basada en firmas. Estos sistemas monitorean y analizan el tráfico de red en busca de actividades sospechosas o maliciosas, y pueden tomar medidas para bloquear o mitigar los ataques.

Por último, es importante hacer copia de seguridad con encriptación, estas soluciones permiten realizar copias de seguridad de los datos críticos y facilitan la recuperación en caso de pérdida o corrupción de la información. Con estas recomendaciones dada el Instituto Nicaragüense de Energía tendrá todo el avance tecnológico para proteger la red cableada e inalámbrica del INE.

17. Bibliografía

A. FOROUZAN, B. ((2002)). *TRANSMISION DE DATOS Y REDES DE COMUNICACIONES.*

Madrid: McGrawHill.

Andina, F. (2014). *REDES ADMINISTRACION DE SERVIDORES.* Buenos Aires.

B., K. A. (2013). *Hacking Etico 101.*

Barker, K. &. (s.f.). *CCNA Security 640-554.* 800 East 96 th Street Indianapolis,IN 46240: Pearson Education,Inc.

CISCO. (2018). *Curricula de CCNA del Modulo 1-4.*

Fortinet. (s.f.). *Download Firmware*. Obtenido de https://support.fortinet.com/Download/FirmwareImages.aspx

Fortinet. (s.f.). *Recurso de Fortimail*. Obtenido de https://docs.fortinet.com/product/fortigate/admin-%20guides

Garcia Rambla, J. L. (2017). *Ataques en redes de datos IPV4 e IPV6.* España, tercera edición revisada y ampliada.

Huerta, A. V. (Julio, 2002). *SEGURIDAD EN UNIX Y REDES.*

James O. Coplien, R. C. (2012). *Código Limpio.* Madrid, España.: ANAYA.

M Carling, S. D. (s.f.). *Guía Avanzada Administración de Sistemas Linux.* Madrid, México: Prentice Hall.

Marchionni, E. A. (s.f.). ADMINISTRADOR DE SERVIDORES. *USERS*.

[M c A f e e . (s.f.). *McAfee Network Security Platform.* Obtenido de

https://community.mcafee.com/t5/Network-Security-Platform-NSP/bd-p/network-security-platform-expert-center

Syed M.Sarwar, R. K. (s.f.). *El Libro de Unix.* Madrid: Addison W esley.

TANENBAUM, A. S. (2012). *Redes de Computadoras.* Mexico:PEARSON.

Tori, C. (2008). *Hacking Etico.* Buenos Aires, Argentina.

Zemánek, J. (2004). *CRACKING SIN SECRETOS.* RA~MA.

18. Anexos:

18.1 Diagrama Final de INE

En la Fig. 1A.1 observamos el diagrama de la red de computadora del Instituto INE al completar todos nuestros objetivos.

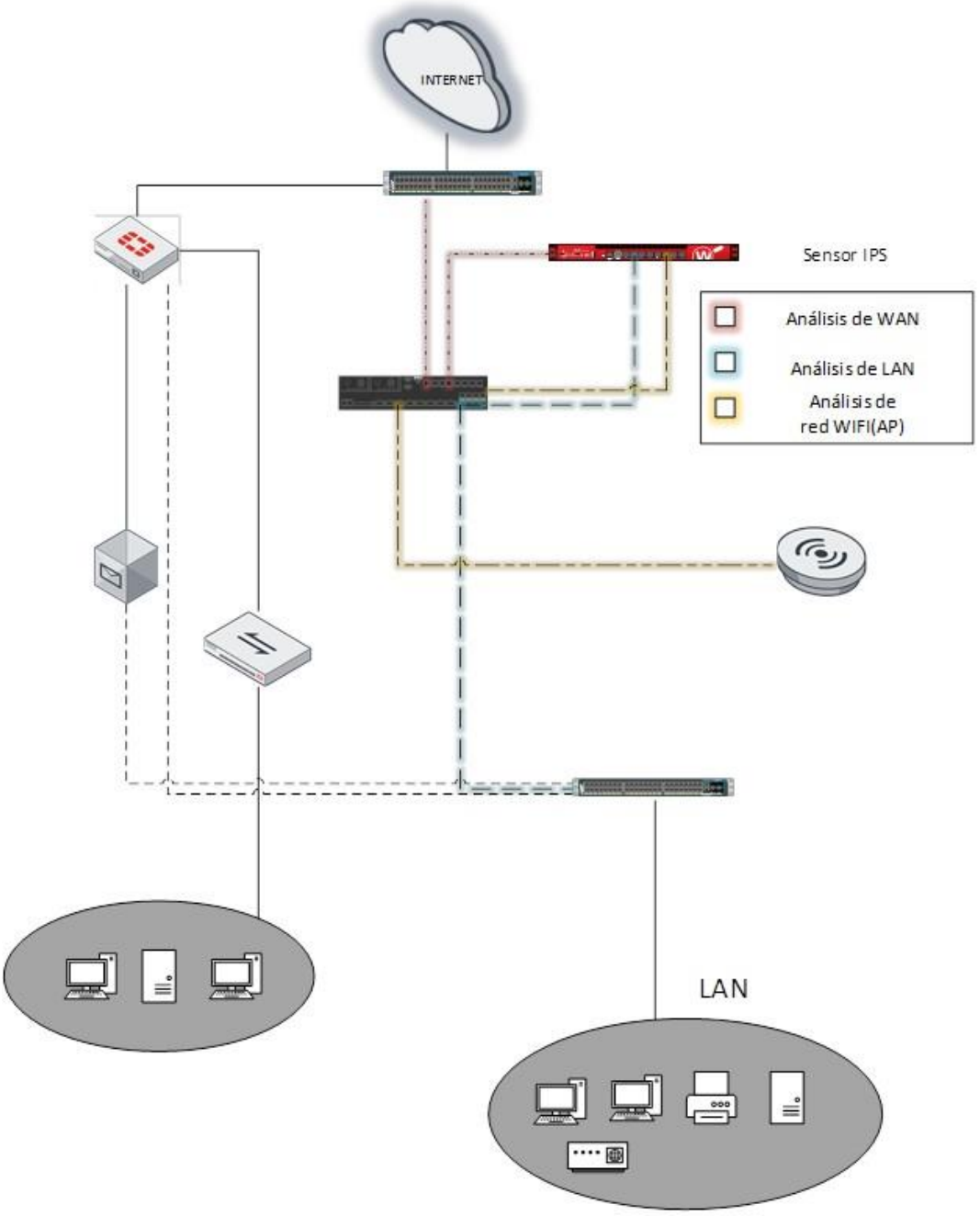

Ilustración 32 Diagrama de la red INE "referencia propia"

Status de un SGSI bajo norma ISO/IEC 27001:2013, Declaración de Aplicabilidad (SoA) y hoja de trabajo para status de controles

(análisis "gap" o de brecha)

Introducción

Esta hoja de trabajo se usa para registrar y hacer seguimiento del status de su organización a medida que implementa los elementos obligatorios y discrecionales de la norma ISO/IEC

El cuerpo principal de la ISO/IEC 27001 especifica formalmente un número de requisitos obligatorios que deben cumplirse con el objeto de que un SGSI o Sistema de Gestión de la Seguridad de la Información sea certificado bajo la norma. Todos los requisitos obligatorios para la certificación son relativos al sistema de gestión más que a los riesgos de la información y a los controles de seguridad que sean aplicados. Por ejemplo, la norma requiere que la dirección determine los riesgos de seguridad de la información de la organización, realizar una De todas formas, el Anexo A de la 27001 da la pauta de un conjunto de controles de seguridad de la información que el sistema de gestión típicamente gestionaría, dado que de hecho son aplicables a la organización (lo que depende en sus riesgos de seguridad de la **Instrucciones**

- 1. Diseñar e implementar un SGSI cumpliendo con todos los elementos obligatorios especificados en el cuerpo principal de la Norma ISO/IEc 27001, usando los selectores de opciones en la columna de status de la hoja "Requisitos obligatorios SGSI".
- 2. Identificar y realizar una apreciación de los riesgos de seguridad de la información que enfrentan aquellas partes de la organización que están declaradas en el alcance de su SGSI, identificando cualquiera de los controles del Anexo A que no sean aplicables utilizando los selectores de opciones en la columna de status en la hoja "Controles del Anexo A". Nota: ¡no se sienta limitado por el Anexo A! Adapte la hoja, modificando la redacción y agregando las
- 3. Sistemáticamente revise y registre el status de sus riesgos de seguridad y controles,
- 4. Una vez que su SGSI esté operando normalmente, las métricas luzcan bien y haya acumulado la suficiente evidencia ("registros"), puede ser formalmente auditado para cumplimiento de ´27001 por una entidad de certificación acreditada (ACB, accredited certification body en inglés). Ellos revisarán que su SGSI cumpla con los requisitos obligatorios de la norma, y que los riesgos de seguridad de la información dentro de su alcance hayan sido **Historial de la documentación y agradecimientos** Bala Ramanan donó la versión original de la ISO/IEC 27001:2005 de la hoja de trabajo de requisitos 27001. Joel Cort agregó la tabla del SoA. Gary Hinson se las ingenió para Ed Hodgson actualizó el documento de trabajo para la ISO/IEC

27001:2013. Gary Hinson se inspiró con la redacción y el formato, dividiendo las métricas y creando una versión más simple Christian Breitenstrom actualizó el documento para reflejar la ISO/IEC
27001:2022 y la ISO/IEC 27002:2022. Gary la emprolijó un poco, lista para publicarla en el ISO27k Toolkit una **Copyright**

Este trabajo tiene el copyright © 2022, ISO27k Forum, derechos reservados. Está protegido bajo la licencia Commons Attribution-Noncommercial-Share Alike 3.0 (no comercial-se puede compartir). Está permitido reproducir, hacer circular, usar y crear trabajos derivados de esta hoja de cálculo de trabajo siempre y cuando (a) no sea vendido ni incorporado en un producto **ambas ISO/IEC 27001 and 27002 para que esto tenga algún sentido, y otras normas de la familia ISO27k son muy recomendables también.**

Métrica ISO/IEC 27001

Estado	**Significado**	**Proporción de requerimientos SGSI**	**Proporción de controles de seguridad de la información**
? Desconocido	No ha sido verificado	**0%**	**0%**
Inexistente	No se lleva a cabo el control de seguridad en los sistemas de información.	**12%**	**12%**
Inicial	Las salvaguardas existen, pero no se gestionan, no existe un proceso formal para realizarlas. Su éxito depende de la buena suerte y de tener personal de la alta calidad.	**37%**	**61%**
Repetible	La medida de seguridad se realiza de un modo totalmente informal (con	**15%**	**0%**

	procedimientos propios, informales). La responsabilidad es individual. No hay formación.		
Definido	El control se aplica conforme a un procedimiento documentado, pero no ha sido aprobado ni por el Responsable de Seguridad ni el Comité de Dirección.	**0%**	**19%**
Administrado	El control se lleva a cabo de acuerdo a un procedimiento documentado, aprobado y formalizado.	**30%**	**2%**
Optimizado	El control se aplica de acuerdo a un procedimiento documentado, aprobado y formalizado, y su eficacia se mide periódicamente mediante indicadores.	**7%**	**5%**
No aplicable	A fin de certificar un SGSI, todos los requerimientos principales de ISO/IEC 27001 son obligatorios. De otro modo,	**0%**	**0%**

	pueden ser ignorados por la Administración.		

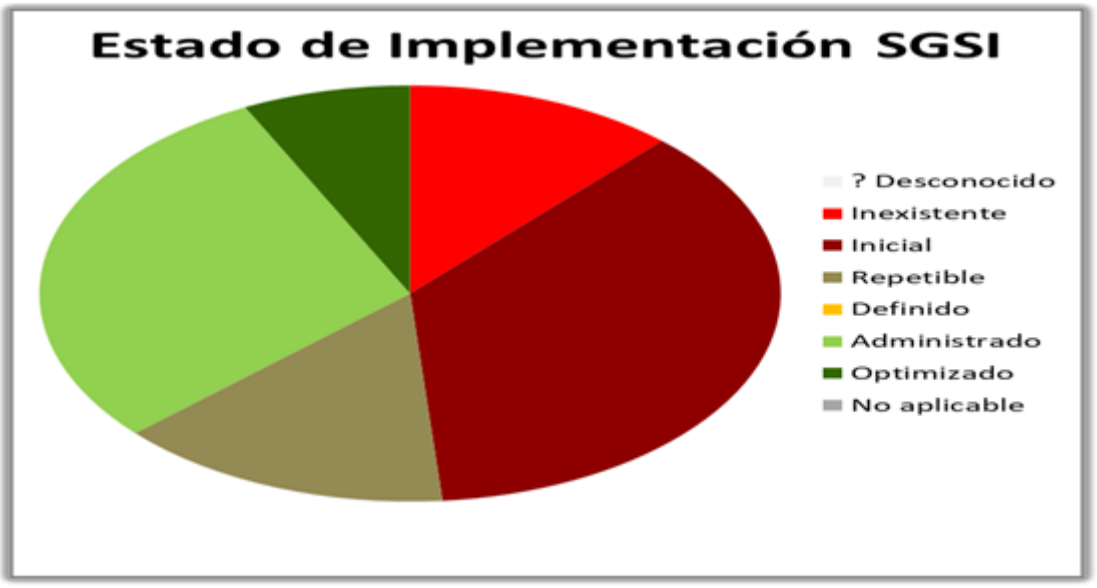

Ilustración 34 Estado de Implementacion SGSI

Ilustración 33 Estado de Controles -Anexo A

PLAN DE AUDITORÍA

	PLAN DE AUDITORÍA	CODIGO: PL- SG-05.01	VERSION: 1.0
		FECHA: 01/06/23	
		REVISADO: Carlos García, Migdalia Carcache (SGSI)	
		APROBADO: Msc. José Antonio Castañeda M	

PLAN DE AUDITORÍA INTERNA DEL SGSI

PLAN DE
OBJETIVO: Verificar que el Sistema de Gestión de Servicios y Seguridad de la Información -SGSSI- se ha implementado de manera eficaz, eficiente y efectiva para satisfacer los requisitos del cliente, y es conforme con los requisitos de las Normas ISO/IEC 20000-1:2011 e ISO/IEC 27001:2005. 1. Determinar la conformidad del Sistema de Gestión de Servicios y Seguridad de la Información con los requisitos de las normas internacionales ISO/IEC o 27001:2013. 2. Evaluar la capacidad para asegurar el cumplimiento de los requisitos legales y reglamentarios aplicables al alcance del Sistema de Gestión de Servicios y Seguridad de la Información y a las normas de requisitos de gestión. 3. Determinar la eficaz implementación y mantenimiento del Sistema de Gestión de Servicios y Seguridad de la Información. 4. Revisión de los controles de seguridad del Anexo A ISO/IEC 27001:2013 incluidos en la Declaración de Aplicabilidad SoA.
ALCANCE: Normalización en Gestión de Servicios y Seguridad de la Información, basados en los estándares internacionales ISO/IEC 27001:2013 para el INSTITUTO NICARAGUENSE DE ENERGIA., en el ámbito de actualización y mejora continua. **Procesos Estratégicos** (Revisión por la Dirección y Comité, Acciones Correctivas y Preventivas, Objetivos del Sistema de Gestión y Auditorías Internas); **Procesos Operativos** (Informes del Servicio, Gestión de Niveles de Servicio, Gestión de la Capacidad, Gestión de la Disponibilidad, Gestión Financiera, Gestión de Configuración, Gestión de Cambios, Gestión de Entregas y Despliegue, Gestión de Incidentes y Peticiones, Gestión de Problemas, Gestión de Relaciones con el Cliente, Gestión de Suministradores); **Procesos de Soporte** (Control de Documentos y Registros, Gestión de RRHH, Gestión de Incidentes y Peticiones, Gestión de Riesgos, Gestión de Equipos de Informáticos, Cumplimiento de Requisitos Legales, Gestión de la Continuidad, Gestión de Accesos, Gestión de Operaciones y Supervisión Técnica).
CRITERIOS: Normas ISO/IEC 27001:2013 más la documentación del Sistema de Gestión de Servicios y Seguridad de la Información y los Requisitos Legales.
Método de Auditoría: (Entrevistas, Cuestionarios con Lista de Verificación y Participación del Auditado, Muestreo, Revisión de
Auditado: Persona 1 (Carlos García), Persona 2 (Migdalia Carcache)
TIPO AUDITORIA: Auditoría Interna
FECHA: 15 de agosto 2023
SITIO: INE, MANAGUA, NICARAGUA

El presente plan corresponde a la programación de la primera auditoría interna del Sistema de Gestión de Servicios y de Seguridad de la Información, conforme a lo establecido por el Comité del Sistema de Gestión. Esta auditoría corresponde a la primera revisión del estado de cumplimiento de los requisitos de la ISO/IEC 27001:2013 antes del inicio del Pilotaje del SG.

Proceso / área /	Documentos de	Responsable del SGSSI /Proceso	Fecha	Auditor	Referenci	Observaciones
P-SG Procesos del Sistema de Gestión	**M-SG-01 Manual del Sistema de Gestión P-SG-02 Control de Documento y Registros P-SG-03 Gestión de RRHH P-SG-04 Revisión por la Dirección y Comité P-SG-**	**Persona 1**	**15/08/2023**	**Persona 2 (Auditor Interno – EXTERNO AUDITOR)**		Fecha y Auditor son referenciales
P-PS Procesos de la Provisión del Servicio	**P-PS-01 Gestión de Niveles de Servicio P-PS-02 Informes del Servicio P-PS-03 Gestión de Capacidad**	**Persona 1**	**15/08/2023**	**Persona 2 (Auditor Interno – EXTERNO AUDITOR)**		Fecha y Auditor son referenciales
P-RS Procesos de Resolución	**P-RS-01 Gestión de Incidentes y Peticiones P-RS-02 Gestión de**	**Persona 1**	**15/08/2023**	**Persona 2 (Auditor Interno –**		Fecha y Auditor son referenciales

Proceso / área /	Documentos de	Responsable del SGSSI /Proceso	Fecha	Auditor	Referenci	Observaciones
P-CT Procesos de Control	**P-CT-01 Gestión de Configuración P-CT-02 Gestión de Cambios**	**Persona 1**	**15/08/2023**	**Persona 2 (Auditor Interno – EXTERNO**		Fecha y Auditor son referenciales
P-RL Procesos de Relaciones	**P-RL-01 Gestión de Relaciones con el Cliente P-RL-02 Gestión de Suministradores**	**Persona 1**	**15/08/2023**	**Persona 2 (Auditor Interno – EXTERNO AUDITOR)**		Fecha y Auditor son referenciales
P-SI Procesos de Seguridad de Información	**P-SI-01 Gestión de Riesgos P-SI-02 Gestión de Equipos Informáticos P-SI-03 Cumplimiento de Req. Legales P-SI-04 Gestión de la Continuidad**	**Persona 1**	**15/08/2023**	**Persona 2 (Auditor Interno – EXTERNO AUDITOR)**		Fecha y Auditor son referenciales

¡Claro que sí, Carlos! Aquí tienes un esquema para una presentación sobre la norma ISO 27001, que detalla tanto las cláusulas como los anexos:

1.1.1. ISO 27001: Introducción a la Gestión de la Seguridad de la Información

1.1.1.1. 1. ¿Qué es ISO 27001?

- Definición de la norma ISO 27001.
- Su propósito principal: Establecer, implementar, mantener y mejorar un Sistema de Gestión de Seguridad de la Información (SGSI).
- Importancia de proteger la confidencialidad, integridad y disponibilidad de la información.

1.1.1.2. 2. Estructura de la ISO 27001

- Basada en el modelo Planificar-Hacer-Verificar-Actuar (PDCA).
- Componentes principales: **Cláusulas (requisitos obligatorios)** y **Anexos (controles opcionales)**.

1.1.2. Cláusulas principales de la norma ISO 27001

1. **Contexto de la organización**:
- Identificación de partes interesadas.
- Alcance del SGSI.
2. **Liderazgo**:
- Compromiso de la alta dirección.
- Política de seguridad de la información.
3. **Planificación**:

- Gestión de riesgos y oportunidades.
- Declaración de aplicabilidad (SoA).

4. **Soporte**:
- Recursos necesarios, competencias y sensibilización.
- Control de documentación.

5. **Operación**:
- Implementación y gestión de controles.

6. **Evaluación del desempeño**:
- Auditorías internas y revisión por la dirección.

7. **Mejora continua**:
- Gestión de no conformidades.
- Acciones correctivas.

1.1.3. Anexo A: Controles de Seguridad de la Información

El Anexo A incluye 14 categorías con un total de 114 controles (basado en versiones anteriores; revisa la última edición):

1. **Políticas de seguridad**.
2. **Organización de la seguridad de la información**.
3. **Gestión de activos**.
4. **Control de accesos**.
5. **Criptografía**.
6. **Seguridad física y del entorno**.
7. **Seguridad de operaciones**.
8. **Seguridad en las comunicaciones**.
9. **Adquisición, desarrollo y mantenimiento de sistemas**.
10. **Relaciones con proveedores**.
11. **Gestión de incidentes de seguridad**.
12. **Aspectos de seguridad de la continuidad del negocio**.

13. **Cumplimiento legal, regulatorio y contractual**.
14. **Revisión de los controles y actualización periódica.**

1.1.4. Conclusión

- La ISO 27001 proporciona un marco robusto para la gestión de la seguridad de la información.
- Ayuda a reducir riesgos, cumplir regulaciones y generar confianza.

¡Espero que este esquema sea útil para estructurar tu presentación, Carlos! Si necesitas ampliarla o agregar gráficos, estoy aquí para ayudarte.

La norma **ISO/IEC 27001** es un estándar internacional para la gestión de la seguridad de la información en una empresa. Su objetivo es establecer, implementar, mantener y mejorar continuamente un **Sistema de Gestión de Seguridad de la Información (SGSI)** para proteger la confidencialidad, integridad y disponibilidad de la información.

1.2. 1. Significado de la ISO 27001

ISO 27001 ayuda a las organizaciones a **gestionar los riesgos de seguridad de la información**, protegiendo los datos sensibles de amenazas como el acceso no autorizado, la pérdida o el robo. Se aplica a empresas de cualquier tamaño y sector, garantizando el cumplimiento de **buenas prácticas** y **requisitos legales**.

1.2.1. Beneficios de su implementación:

- Protección de la información sensible.
- Cumplimiento con regulaciones y leyes (como GDPR, Ley de Protección de Datos).
- Mejora de la confianza con clientes y socios.

- Reducción de riesgos de seguridad.

1.3. 2. Cláusulas de la ISO 27001

La norma ISO 27001 está estructurada en **10 cláusulas** (0 a 10), donde las más importantes para la implementación del SGSI son de la **4 a la 10**:

1.3.1. Cláusulas clave:

- **4. Contexto de la organización:** Identificar factores internos y externos que afectan la seguridad de la información.
- **5. Liderazgo:** Compromiso de la alta dirección en la gestión del SGSI.
- **6. Planificación:** Evaluación de riesgos y oportunidades de seguridad.
- **7. Apoyo:** Recursos, competencia y comunicación para el SGSI.
- **8. Operación:** Implementación de los controles de seguridad.
- **9. Evaluación del desempeño:** Auditorías y revisión del SGSI.
- **10. Mejora:** Acciones correctivas y mejora continua del SGSI.

1.4. 3. Anexos de la ISO 27001

El **Anexo A** de la norma es una guía con **114 controles de seguridad**, organizados en **14 dominios**, que ayudan a mitigar riesgos. Algunos de los más importantes son:

- **A.5 Políticas de seguridad de la información:** Definición de políticas y procedimientos.
- **A.6 Organización de la seguridad de la información:** Roles y responsabilidades.

- **A.9 Control de acceso:** Gestión de accesos a información crítica.
- **A.12 Seguridad en operaciones:** Protección contra malware, copias de seguridad.
- **A.13 Seguridad en comunicaciones:** Protección de datos en tránsito.
- **A.18 Cumplimiento:** Cumplimiento de requisitos legales y contractuales.

1.5. Conclusión

Implementar **ISO 27001** ayuda a las empresas a fortalecer la seguridad de su información, reduciendo riesgos y cumpliendo con normativas internacionales. Su adopción permite una gestión estructurada de la seguridad, mejorando la confianza y la competitividad en el mercado.

18.2 Glosario de términos:

AP: Punto de Acceso

Bandwidth: Ancho de

Banda

Brute Force Attack: Ataque a Fuerza Bruta

CSMA/CD: Carrier Sense Multiple Access / Collition Detection

Domain: Dominio

DHCP: Dynamic Host Configuration Protocol

DoS: Denial of Service

DDoS: Distributed Denial of Service Attack

DNS: Domain Name System

DMZ: Demilitarized Zone

Ethernet: Diseño de red de área local normalizado como IEEE 802.3

Firewall: Cortina de Fuego

GUI Graphic User

Interface: Interface Gráfico de

Usuario

Hacker: Experto en informática capaz de entrar en sistemas cuyo acceso es restringido

INTERNET: Conjunto de redes y ruteadores que utilizan el protocolo TCP/IP y que funciona como una sola gran red.

INTRANET: Se llaman así a las redes tipo Internet pero que son de uso interno

IEE: Institute of Electrical and Electronics Engineers

ITU: International Telecommunication Union

ISO: International Organization for Standardization

ISP: Internet Service Provider
IPS: Intrusion Prevention System
IMAP: Internet Message Access Protocol

LAN: Local Area Network
Linux: Versión Shareware y/o Freeware del conocido sistema operativo Unix
Packet: Paquete Cantidad mínima de datos que se transmite en una red
PING QoS: Quality of Service